

GREYNOC SECURITY PLAYBOOKS

Transmission & Physical Layer Playbooks

Radio-frequency spectrum and nanometer-scale optical media - detection, response, and the coverage audit behind the collection.

DOCUMENT

GN-PUB-TXPHY-001

PUBLICATION DATE

2026-08-09

SOURCE

GreyNOC/Playbooks

VERSION

v1.1.0

CLASSIFICATION

PUBLIC // GreyNOC Field Reference

DISCIPLINE

Baseline-derived, locally calibrated

Detection is bounded by what you instrument. Passive interception of RF and optical media is undetectable in principle - the control is cryptographic, not telemetric. Every threshold in these playbooks is a deviation from a locally recorded baseline; published absolute values are not portable between sites. An empty alert queue for an uninstrumented band or span is a coverage gap, not a clean result. MITRE mappings are pinned to **ATT&CK v19.2** (Enterprise and ICS); the ICS tactic set is distinct from Enterprise, and both version their technique names, IDs, and tactic assignments - re-map to the collection your platform carries (CONVENTIONS Section 4).

PUBLICATION MAP

Contents

01	QA/QC - Physical-Layer & Transmission-Medium Coverage	03	TX-02 - Nanometer-Scale Optical Data Transmission, Reception & Intrusion Handling
02	TX-01 - RF & Radio-Spectrum Intrusion Detection & Response	04	CONVENTIONS

SOURCE: QAQC-physical-layer-coverage.md

QA/QC - Physical-Layer & Transmission-Medium Coverage

Audit scope. Whether the GreyNOC playbook library covers the physical transmission layer - radio-frequency and optical media - as a detection and response domain.

Audited artifact set. All 50 Markdown files at repository root (20 Detection & Response, 27 AI · Post-Quantum · E2EE, plus README.md, CONVENTIONS.md, SECURITY.md) as of this audit.

Verdict. Gap confirmed - the library had zero physical-layer coverage before this audit. Every playbook in both collections begins at Layer 2 or above and treats the transmission medium as trusted, unexamined substrate. Two new playbooks (TX-01, TX-02) were authored to close the highest-consequence portion of that gap; the remainder is enumerated in Section 5 as open work.

Per the house rule - *reproducible or it didn't happen* - every finding below carries the command that produces it.

1. Method

The audit is a term-presence sweep with word boundaries, followed by manual context review of every hit. Word boundaries matter: an unanchored `grep -ric "RF"` returns 163 hits across the library and an unanchored `LTE` returns 53, but **all** of them are substring artifacts (`surface`, `perform`, `filter`, `alternate`). A naive sweep would have reported this domain as covered. It is not.

Reproduce with:

```
for t in 'radio' 'RF' 'spectrum' 'wireless' 'Wi-Fi' '802.11' 'bluetooth' 'cellular' 'LTE' '5G' \
  'GNSS' 'GPS' 'jamming' 'SDR' 'antenna' 'optical' 'photonic' 'fibre?' 'laser' 'DWDM' \
  'OTDR' 'Li-Fi' 'TEMPEST' 'EMSEC' 'air-gap' 'satellite' 'microwave' 'physical layer' \
  'side-channel' 'QKD'; do \
  printf "%-16s %3s %s\n" "$t" "$(grep -riEo "\b($t)\b" *.md | wc -l)" "$(grep -riEl "\b($t)\b" *.md | tr '\n' ' '); \
done
```

2. Findings

F-01 - Zero coverage of radio-frequency media (*pre-existing, now partially closed*)

Twenty-four of the thirty terms swept returned **zero** matches across all 50 files: `radio`, `RF`, `spectrum`, `wireless`, `802.11`, `bluetooth`, `LTE`, `5G`, `GNSS`, `GPS`, `jamming`, `SDR`, `antenna`, `microwave`, `TEMPEST`, `EMSEC`, `air-gap`, `physical layer` - and, per F-02, the entire optical set.

Consequence. The library's Detection & Response collection claims coverage "across the intrusion lifecycle," but a documented initial-access path - an adversary who never touches a network port - had no playbook. D&R-03 `Distributed Port Scan` presumes an IP reconnaissance surface; D&R-17 `Data Exfiltration` enumerates cloud, C2, and alternate *protocols* but no alternate *medium*. ATT&CK T1011 `Exfiltration Over Other Network Medium` and T1200 `Hardware Additions` were unmapped anywhere in the library.

Disposition. Closed for the enterprise-relevant RF bands by TX-01 - RF & Radio-Spectrum Intrusion. Residual gaps in Section 5.

F-02 - Zero coverage of optical media (*pre-existing, now closed*)

optical, photonic, fiber/fibre, laser, DWDM, OTDR, Li-Fi, and QKD each returned **zero** matches across all 50 files.

Consequence - this is the more serious of the two. The AI · PQ · E2EE collection is built on the harvest-now-decrypt-later threat model, and PB-02 Harvest-Now-Decrypt-Later Exposure is explicitly a *bulk-capture detection* playbook. A passive fiber tap is the single highest-yield bulk-capture position available to a well-resourced adversary - it is silent, it is upstream of every application control, and it sees the aggregate. The collection reasoned about what an HNDL adversary would *do with* captured ciphertext without ever addressing where the capture happens. PB-02 had no counterpart describing how the traffic gets harvested at the medium.

Disposition. Closed by TX-02 - Nanometer-Scale Optical Data Transmission, Reception & Intrusion Handling, which is cross-referenced from the HNDL threat model.

F-03 - All six incidental hits are contextual, not coverage

Six word-boundary matches exist across four terms. Every one was manually reviewed; none constitutes physical-layer detection content:

File	Line	Term	Actual context	Coverage?
01-password-spraying.md	105	Wi-Fi	Guest Wi-Fi as a shared-NAT false-positive source	No
05-impossible-travel.md	117	satellite	Satellite ISPs as a geolocation-accuracy caveat	No
08-malware-beaconing.md	128	Wi-Fi	MDM check-ins over Wi-Fi as a false positive	No
12-pq-e2ee-realtime-media.md	154	Wi-Fi, cellular	Wi-Fi ↔ cellular handoff as a renegotiation FP	No
08-bugbounty-crypto-implementation-defects.md	97, 197	side-channel	C10 - computational side channels (timing, fault, residue), not electromagnetic	No
20-ai-serving-plane-isolation.md	152	side-channel	Inference timing/cache side channels	No
27-pq-capacity-interoperability-vendor-assurance.md	48	satellite	Satellite paths as an interop test condition	No

The pattern is consistent and worth naming: where the physical layer appears at all, it appears as *something that generates false positives* - never as something that generates detections.

Note on C10 and Section 8.1. The pre-existing C10 – Side-channel, fault and secret-residue exposure class in PB-08 covers computational side channels only. TX-01's electromagnetic emanation (TEMPEST) material and TX-02's optical-emission material are a different physical phenomenon and are deliberately **not** filed under C10. Do not merge them; a triager reading C10 expects a timing or fault oracle.

F-04 - CONVENTIONS.md Section 5 cross-reference notation was two-collection-only (*now closed*)

Section 5 stated that "the two collections number independently" and defined only PB-NN and D&R-NN. Adding a third collection without amending Section 5 would have made TX-NN an undefined citation form and reintroduced exactly the bare-number ambiguity Section 5 exists to prevent.

Disposition. `CONVENTIONS.md` Section 5 amended to define TX-NN and to restate the rule as *three* independently numbered collections. `CONVENTIONS.md` Section 8.1 amended to record that the TX track intentionally owns no defect-class prefix.

F-05 - Detection-telemetry honesty applies with unusual force to this track (*advisory*)

`README.md` step 2 already warns that PQ/E2EE detection "depends on handshake- and key-level visibility that many estates do not yet log." For the physical layer the problem is a category worse: the telemetry frequently **cannot be produced at all** without hardware the organization does not own - spectrum sensors, WIPS overlays, OTDR ports, tapped optical monitor ports.

Both new playbooks therefore lead with a telemetry-tier model that states plainly what is detectable at each level of investment, and both state which intrusion classes remain **undetectable** at Tier 0. A playbook that implies a detection an estate cannot actually run is a fabrication under the house rule, whether or not the logic itself is sound.

3. Coverage matrix - transmission medium × library

Medium	Before this audit	After
Ethernet / IP / application protocols	Covered (D&R-01-18, PB-03/09/12)	unchanged
Wi-Fi (802.11)	None	TX-01 Section 5.1
Bluetooth / BLE	None	TX-01 Section 5.2
Cellular (LTE / 5G NR)	None	TX-01 Section 5.3
GNSS reception	None	TX-01 Section 5.4
Sub-GHz ISM / LPWAN (LoRa, Zigbee, Z-Wave, 433/868/915 MHz)	None	TX-01 Section 5.5
Microwave / satellite backhaul	None	TX-01 Section 5.6
Electromagnetic emanation (TEMPEST)	None	TX-01 Section 5.7 (scoped, detection-limited)
Single-mode / multimode fiber	None	TX-02 Section 6
Free-space optical & laser links (incl. orbital ISL)	None	TX-02 Section 6.5
Visible-light comms / Li-Fi / IR	None	TX-02 Section 6.6
Optical air-gap covert channels	None	TX-02 Section 6.7
Ultrasonic / acoustic covert channels	None	still open - see Section 5
NFC / RFID	None	still open - see Section 5
Power-line / conducted emissions	None	still open - see Section 5

4. Conformance check - new TX track against `CONVENTIONS.md`

Both new playbooks were checked against every convention the library enforces:

Requirement	Source	TX-01	TX-02
GreyNOC detection structure (overview -> mapping -> strategy -> indicators -> logic -> example data -> investigation -> FP -> tuning -> response -> escalation -> analyst notes -> summary)	README.md ¶3	Pass	Pass
ATT&CK cited as ID + name; no forced tags where mapping is absent	Section 4	Pass - unmapped phenomena listed explicitly	Pass - same
ATLAS citations carry collection version	Section 4	N/A - no ATLAS mapping	N/A
Example addresses in RFC 5737 / RFC 3849 space	Section 5	Pass	Pass
Detection logic is JSON-shaped pseudocode, not a SIEM query	Section 5	Pass	Pass
Cross-references use the PB-NN / D&R-NN / TX-NN form, never a bare number	Section 5 (as amended, F-04)	Pass	Pass
Standardized PQC names (ML-KEM / ML-DSA), submission names only as aliases	Section 1	N/A	Pass
No defect-class prefix invented outside the Section 8.1 registry	Section 8.1	Pass - no prefix	Pass - no prefix
ROE Section 6/Section 7 applicability	Section 6, Section 7	N/A - neither is a bug-bounty playbook	N/A

Two conformance notes from the original audit - the first has since been closed:

- 1. ATT&CK tactic placement - annotated at audit time, asserted since 2026-08-09.** Both playbooks map ICS-matrix techniques alongside Enterprise ones: T0860, T0887, T0830 and T0814 in TX-01, T0842 and T0830 in TX-02. At audit time the ICS rows carried "verify against your ATT&CK version" in place of a tactic, per Section 4's "say so rather than forcing a tag." **That deviation is now closed.** The library-wide re-verification against **ATT&CK v19.2** filled every one in (T0887 Discovery/Collection, T0830 Collection, T0842 Discovery), and corrected two Enterprise rows that the audit did not catch: T1599 (TX-01) and T1600 (TX-02) were tagged to the retired "Defense Evasion" tactic and are now **Defense Impairment** (TA0112). Both tables assert tactics against a pinned version and keep the re-verification note. Section 4 was strengthened at the same time to *require* that pinned version rather than permit a bare annotation - so what was a deviation is now the rule.
- 2. Physical-measurement thresholds are parameterized, never hardcoded as universal.** Optical tap-loss and RF noise-floor thresholds depend entirely on link budget, hardware, and environment. Both playbooks require the reader to establish a local baseline and state the detection threshold as a deviation from it. A published absolute number would be unreproducible in any estate but the one it came from.

5. Residual gaps - open work

The TX track does **not** yet cover the following. Each is a legitimate candidate for TX-03 +; none is closed by TX-01 or TX-02, and no playbook should be read as covering them.

- **NFC / RFID** - badge cloning, relay attacks against physical access control. Adjacent to D&R-06 and D&R-15 but a distinct medium with distinct telemetry.
- **Ultrasonic and acoustic covert channels** - air-gap bridging via speakers/microphones, ultrasonic cross-device tracking beacons.
- **Power-line and conducted emissions** - data over power, and conducted EM leakage.
- **Specialist RF protocol families** - ADS-B/avionics, marine AIS, TETRA/P25 land mobile radio, DECT. High consequence in specific verticals, out of scope for a general enterprise track.
- **Optical-layer quantum key distribution as an operational detection surface.** TX-02 Section 9 states the policy position (QKD is not a substitute for PQC, and PQC per CONVENTIONS Section 1 remains the GreyNOC default) but does not provide QKD-specific monitoring content. *(One gap listed here at first audit - the TX track's absence from the compiled PDF - was closed during remediation; see Section 6.5.)*

6. Actions taken

1. Authored TX-01-rf-spectrum-intrusion.md - closes F-01.
 2. Authored TX-02-optical-nm-data-transmission-intrusion.md - closes F-02.
 3. Amended CONVENTIONS.md Section 5 (three-collection cross-reference notation) and Section 8.1 (TX track owns no defect-class prefix) - closes F-04.
 4. Added the Transmission & Physical Layer collection to README.md and index.html.
 5. Extended the PDF builder to a multi-publication pipeline (scripts/build_ai_pqc_pdf.mjs -> scripts/build_playbook_pdfs.mjs), adding a transmission publication (GN-PUB-TXPHY-001 , v1.0.0). The AI/PQC publication rebuilt at an **identical 151 pages**, confirming the refactor is output-preserving; its byte size grew by the CONVENTIONS.md Section 5/Section 8.1 edits it carries as a source. The new GreyNOC_Transmission_Physical_Layer_Playbooks.pdf is 39 pages with 80 outline entries.
 6. Logged residual gaps in Section 5 above rather than implying the medium is now fully covered.
-

GreyNOC - detection-engineering-first. Reproducible or it didn't happen.

SOURCE: TX-01-rf-spectrum-intrusion.md

TX-01 - RF & Radio-Spectrum Intrusion Detection & Response

TX-01 - RF & Radio-Spectrum Intrusion Detection & Response

1. Overview

Every control in a modern security program assumes the adversary arrives over a wire. Radio does not require one. An RF adversary needs proximity and an antenna - not a credential, not a port, not an egress path through the proxy. The traffic never appears in NetFlow because it never enters the network the SOC instruments.

This playbook covers detection and response for intrusions carried over radio-frequency media, roughly 3 kHz to 300 GHz: Wi-Fi, Bluetooth/BLE, cellular, GNSS reception, sub-GHz ISM and LPWAN, and microwave/satellite backhaul. It also scopes electromagnetic emanation (TEMPEST) honestly - including the parts an ordinary enterprise cannot detect.

The organizing insight is the same one that drives D&R-08 *Malware Beaconing*: **detection runs on geometry, not payload**. Most RF attack traffic is encrypted, proprietary, or deliberately malformed. What gives it away is where it comes from, how strong it is, how it behaves over time, and whether its claimed identity matches its physical position.

The second organizing insight is harder to accept: **passive reception is undetectable in principle**. A receiver emits nothing. An adversary capturing your Wi-Fi, your BLE advertisements, or your microwave backhaul leaves no signal to detect - ever, at any budget. Detection covers *active* RF intrusion; passive interception is addressed by making the capture worthless, which is a cryptographic control, not a detection one. Any RF playbook that claims otherwise is selling something.

Related: TX-02 (optical media, the other half of the physical layer), D&R-17 (exfiltration - RF is an alternate medium, not just an alternate protocol), D&R-15 (persistence - an RF implant is a persistence mechanism), PB-02 (HNDL - passively captured RF is harvested ciphertext).

2. Scope and the RF-BOM

Detection begins with knowing what is *supposed* to be transmitting. The library already builds a CBOM (PB-01) and an AI-BOM (PB-21); the RF equivalent is the same discipline applied to the spectrum plane. Without it there is no baseline, and without a baseline every RF alert is unfalsifiable.

Record, per emitter and per receiver:

- **Identity** - asset ID, owner, physical location (building/floor/room, and outdoor position for fixed links), business purpose.
- **Radio** - band(s), channel/ARFCN/EARFCN plan, modulation, protocol and version, transmit power, antenna type/gain/polarization/azimuth, duty cycle.
- **Addressing** - BSSID/MAC, BLE address type (public, random static, resolvable private), cell identity, LoRaWAN DevEUI/JoinEUI, device serial.
- **Security posture** - authentication and encryption in use (WPA2-PSK, WPA3-SAE, 802.1X, BLE pairing mode, LoRaWAN join method), management-frame protection status, firmware version, whether keys are per-device or shared.

- **Receive-only assets** - GNSS receivers, telemetry receivers, and anything that consumes radio it does not transmit on. These are the assets most often omitted from inventory and most easily attacked, because *nobody thinks of a receiver as an attack surface*.
- **Expected RF neighborhood** - the transmitters you do not own but always see. Adjacent-tenant APs, the coffee shop below, the operator macro cells. If this is not baselined, every one of them becomes an alert.

An RF-BOM entry with no baseline measurement attached is inventory, not telemetry. Pair each fixed emitter with a recorded reference RSSI at each sensor position, and each receiver with its normal signal-quality range.

3. MITRE ATT&CK Mapping

Technique	ID	Matrix	Tactic
Hardware Additions	T1200	Enterprise	Initial Access
Network Sniffing	T1040	Enterprise	Credential Access, Discovery
Adversary-in-the-Middle	T1557	Enterprise	Collection, Credential Access
Exfiltration Over Other Network Medium	T1011	Enterprise	Exfiltration
Exfiltration Over Other Network Medium: Exfiltration Over Bluetooth	T1011.001	Enterprise	Exfiltration
Exfiltration Over Physical Medium	T1052	Enterprise	Exfiltration
Network Denial of Service	T1498	Enterprise	Impact
Network Boundary Bridging	T1599	Enterprise	Defense Impairment
Wireless Compromise	T0860	ICS	Initial Access
Wireless Sniffing	T0887	ICS	Discovery, Collection
Adversary-in-the-Middle	T0830	ICS	Collection
Denial of Service	T0814	ICS	Inhibit Response Function

Mapping discipline (CONVENTIONS Section 4). This table was verified against **ATT&CK v19.2** (Enterprise and ICS) on **2026-08-09**. **v19 retired the "Defense Evasion" tactic**, renaming TA0005 to **Stealth** and splitting out **TA0112 Defense Impairment**; T1599 landed on the Defense Impairment side, because bridging a network boundary tampers with the control rather than hiding from it. The ICS rows previously left as "verify against your ATT&CK version" are now filled in from the same check - ICS tactic placement is a **separate tactic set** from Enterprise and still has to be re-verified on its own terms. Re-verify every row against the version your platform carries before you tag a detection with it.

Deliberately unmapped. The following have no clean ATT&CK technique, and this playbook says so rather than forcing a tag: **RF jamming as a distinct technique** (T1498 describes network-layer volumetric DoS, not physical-layer denial - the mapping is an analogy, use it with a note), **GNSS spoofing**, **rogue cellular base station / IMSI catcher**, and **electromagnetic emanation capture (TEMPEST)**. Tag these with the internal class from Section 5 and describe the behavior.

4. Detection Strategy - and what each tier can actually see

You cannot detect what you cannot receive. RF detection maturity is a function of hardware, and being honest about the tier you are on is a precondition for trusting an absence of alerts.

Tier 0 - infrastructure-derived. No new hardware. Telemetry from radios you already own: wireless LAN controller and AP logs, client association history and RSSI, retry and PHY-error counters, channel-utilization stats, cellular modem diagnostics on managed endpoints, GNSS receiver status sentences, LoRaWAN network-server join logs. This detects: rogue APs on your own channels, evil twins, association anomalies, most jamming, most GNSS spoofing, and cellular downgrade on *managed* devices. It does **not** detect: transmitters on bands your infrastructure does not tune, RF implants using proprietary sub-GHz protocols, or anything passive.

Tier 1 - dedicated sensing. A WIPS overlay, receive-only SDR sensors, or spectrum analyzers at fixed positions. This adds: wideband unauthorized-emitter discovery, spectral-occupancy baselining, RF implant detection, and direction finding when three or more sensors see the same emitter.

Tier 2 - RF baseline and anomaly program. Continuous spectral occupancy modeling per band, per position, per time-of-day, with drift alerting. This is what turns "there is an unknown signal at 915 MHz" into "there is an unknown signal at 915 MHz that was not here last Tuesday and is strongest near the server room."

The five detectable behaviors. Regardless of tier, active RF intrusion reduces to five shapes:

1. **Presence** - an emitter that should not exist. Detection: identity not in the RF-BOM.
2. **Impersonation** - an emitter claiming an identity that does exist. Detection: the claimed identity and the physical evidence disagree. A BSSID your RF-BOM places on floor 3 cannot legitimately appear at -40 dBm on a floor-8 sensor. **Physical position is the hardest property for an adversary to forge** and should carry the most weight in scoring.
3. **Denial** - energy that prevents reception. Detection: noise floor rises while signal quality falls. The distinguishing feature of jamming versus congestion is that jamming degrades SNR without a corresponding rise in *decodable* traffic.
4. **Injection / replay** - valid-looking frames the legitimate transmitter did not send. Detection: sequence-number discontinuities, duplicate counters, frames arriving with the right identity but the wrong RSSI or timing.
5. **Reception anomaly** - a receiver being fed a lie. Detection: physical implausibility in what the receiver reports (see Section 5.4 for the GNSS case, which is the canonical example).

5. Intrusion Classes and Their Indicators

5.1 Wi-Fi (802.11)

- **Rogue AP on the corporate wire.** An unauthorized AP bridging RF to the internal LAN - the cleanest T1599 Network Boundary Bridging case there is. Indicators: an SSID/BSSID absent from the RF-BOM whose wired-side MAC (or an adjacent MAC in the same OUI block) appears in switch CAM tables; an AP with a consumer OUI on an access port; DHCP leases from an unexpected server.
- **Evil twin.** A rogue transmitting a legitimate SSID. Indicators: correct SSID with a BSSID not in the RF-BOM; correct SSID *and* BSSID but implausible RSSI/position (BSSID spoofing); downgraded security posture (an open or WPA2-PSK twin of an 802.1X network); client roams to a new BSSID with no corresponding RSSI trend.
- **Deauthentication / disassociation flood.** Forced client disconnection, usually as a precursor to evil-twin capture or handshake collection. Indicators: burst of deauth/disassoc frames, mass simultaneous client loss across one AP, reason codes inconsistent with the AP's own logs. 802.11w Protected Management Frames -

mandatory under WPA3 - largely closes this; **an estate seeing deauth floods is telling you PMF is not enforced.**

- **Probe-response / known-beacon abuse.** A rogue answering client probe requests for any requested SSID, harvesting clients with stale preferred-network lists. Indicators: one BSSID beaconing or responding for an implausible number of distinct SSIDs.
- **Handshake capture for offline cracking.** Passive, therefore **not directly detectable** - detect the deauth that provokes the re-handshake, and defend with WPA3-SAE, which removes the offline-dictionary exposure that makes the capture worth doing.

5.2 Bluetooth / BLE

- Unauthorized BLE peripherals advertising inside secure areas; devices whose address type is public/random-static (trackable) where policy requires resolvable private addresses.
- Peripherals paired to corporate endpoints that are absent from the RF-BOM - a BLE HID device is a keystroke injection surface (T1200).
- Exfiltration over Bluetooth (T1011.001): an endpoint with sustained BLE/BR-EDR throughput to an unenrolled peer, especially outside working hours.
- Tracker-class devices persisting with corporate assets or personnel.

5.3 Cellular (LTE / 5G NR)

Detection here is almost entirely endpoint-side, from managed-device modem diagnostics.

- **Rogue base station / IMSI catcher.** Indicators: an unexpected downgrade to 2G/GSM or to a weaker cipher (including null encryption); serving-cell identity not present in the operator's published or previously observed cell database; a cell with abnormally high signal strength for its claimed location; forced reselection away from a stable serving cell; tracking-area updates at an implausible rate; identity requests for permanent identifiers.
- **5G note.** SUCI concealment removes the plain-IMSI exposure that made classic catchers easy, but a downgrade to LTE or 2G re-opens it. **Detect the downgrade, not the catcher.**
- Cellular-enabled rogue devices as an egress bypass: an internal host that also holds a cellular interface is an unmonitored egress path around every proxy control in D&R-17.

5.4 GNSS reception - the canonical receiver attack

GNSS receivers accept unauthenticated broadcast from space, with received power low enough that a local transmitter trivially overrides it. Time, not just position, is the target: a spoofed clock breaks Kerberos, TOTP, certificate validity, log correlation, and financial timestamping.

Spoofing indicators:

- All tracked satellites reporting near-identical C/N₀, or C/N₀ abnormally high and uniform - real constellations produce a spread driven by elevation angle.
- Position or time discontinuity without corresponding motion; receiver clock steering at an implausible rate.
- Tracked PRN set inconsistent with the almanac for that time and location.
- Two or more independent receivers at known separation reporting the same position.
- Loss of RAIM/integrity consistency, or a sudden drop in reported dilution of precision that does not match sky visibility.

Defenses to record in the RF-BOM: multi-constellation and multi-frequency reception, RAIM, antenna placement with sky-only view and terrain masking, a disciplined holdover oscillator sized to survive the outage you plan for, and signal authentication where the constellation offers it - Galileo OSNMA is available today; GPS signal-authentication work is still in development, so do not plan a control around it as though it were deployed.

5.5 Sub-GHz ISM and LPWAN (433 / 868 / 915 MHz, LoRa, Zigbee, Z-Wave)

This is where RF implants live, because the bands are lightly monitored, propagate well through building structure, and support cheap long-range links.

- An emitter in the RF-BOM's "unknown" column with a periodic duty cycle - the RF equivalent of beaconing (D&R-08), and analyzed the same way: inter-burst interval regularity is the signal.
- LoRaWAN join anomalies: repeated join requests from a known DevEUI, join-request replay, or a DevEUI joining from an implausible gateway.
- Replay against building-automation, sensor, or access-control radios: identical payloads with stale rolling counters.

5.6 Microwave and satellite backhaul

- Link-budget degradation inconsistent with weather (a jamming or interference signature versus rain fade - see Section 8).
- Received signal present with elevated bit-error rate and no corresponding fade: consistent with interference or an injection attempt.
- Any point-to-point link carrying unencrypted payload is a passive-capture target with a large standoff distance. Treat it as harvested (PB-02).

5.7 Electromagnetic emanation (TEMPEST) - scoped honestly

Unintentional EM radiation from cables, displays, and processors can carry recoverable information. This is a real phenomenon and a real research area.

It is also, for the overwhelming majority of enterprises, not detectable. The adversary is a passive receiver. There is no emission to alert on, no log to correlate, and no commercially routine control that verifies whether capture occurred. Treating TEMPEST as a *detection* problem produces theater.

Handle it as an architecture and siting problem instead: zone placement, physical standoff distance, shielding where the threat model genuinely warrants it, and - this being the part that generalizes - **not putting the highest-consequence plaintext processing at the building perimeter**. Escalate to a specialist program only where a documented threat model and a regulatory or classification requirement justifies it. Do not file this under PB-08 C10, which covers computational side channels.

6. Sample Detection Logic (JSON-style)

```
{
  "rule_name": "RF - Evil Twin / SSID Impersonation by Position Implausibility",
  "description": "Detects a BSSID advertising a corporate SSID whose observed physical position or identity contradicts the RF-BOM baseline.",
  "data_source": ["WLC.AP.Neighbor", "WIPS.Sensor.Observation", "RFBOM.Emitter"],
  "logic": {
    "window": "15m",
    "for_each": "observed_emitter",
    "where": { "ssid": "in RFBOM.corporate_ssids" },
    "trigger_any": [
      "bssid not in RFBOM.emitter.bssid",
      "abs(observed.rssi_dbm - RFBOM.baseline_rssi_dbm[sensor_id]) > baseline_tolerance_db",
      "observed.security_profile weaker_than RFBOM.emitter.security_profile",
      "observed.bssid seen_at_sensor not_in RFBOM.emitter.expected_sensors"
    ],
    "escalate_if_any": [
      "observed.security_profile == 'open' or 'wpa2-psk' while baseline == '802.1x'",
      "client_count_migrated_to_observed_bssid >= 3 within 5m",
      "deauth_frame_rate[target_bssid] > baseline_p99 within preceding 10m"
    ]
  }
},
```

```

"notes": "baseline_tolerance_db MUST be derived per sensor from a recorded local baseline. There is no portable absolute value; RF propagation is site-specific.",
"severity": "high_when_escalated_else_medium",
"tags": ["T1557", "T1599", "rf_impersonation"]
}

```

```

{
  "rule_name": "RF - Physical-Layer Denial (Jamming) vs. Congestion",
  "description": "Separates jamming from ordinary congestion by requiring noise-floor rise WITHOUT a matching rise in decodable traffic.",
  "data_source": ["WLC.AP.RadioStats", "WIPS.Spectrum", "AP.ClientAssoc"],
  "logic": {
    "window": "5m",
    "group_by": ["ap_id", "band", "channel"],
    "compute": {
      "noise_delta_db": "noise_floor_dbm - baseline_noise_floor_dbm[ap_id, band, hour_of_day]",
      "snr_delta_db": "snr_db - baseline_snr_db[ap_id, band, hour_of_day]",
      "decodable_frame_rate_ratio": "frame_rate / baseline_frame_rate[ap_id, band, hour_of_day]",
      "retry_ratio": "retry_frames / total_frames"
    },
    "having": {
      "noise_delta_db_gte": "site_threshold_db",
      "snr_delta_db_lte": "-site_threshold_db",
      "decodable_frame_rate_ratio_lte": 1.1,
      "retry_ratio_gte": "site_retry_threshold"
    },
    "escalate_if_any": [
      "affected_ap_count >= 3 and shared_physical_zone == true",
      "concurrent mass_deassociation_event",
      "concurrent alarm on physical_security_system in same zone",
      "band in RFBOM.safety_or_ot_critical_bands"
    ]
  },
  "notes": "Congestion raises noise AND decodable traffic together. Jamming raises noise while decodable traffic stays flat or falls. That divergence is the detection.",
  "severity": "high",
  "tags": ["T1498", "T0814", "rf_denial"]
}

```

```

{
  "rule_name": "RF - GNSS Spoofing by Physical Implausibility",
  "description": "Detects GNSS spoofing from internal inconsistency in receiver telemetry and disagreement between independent receivers.",
  "data_source": ["GNSS.Receiver.Status", "NTP.Peer.Stats", "Asset.Inventory"],
  "logic": {
    "window": "10m",
    "for_each": "gnss_receiver",
    "trigger_any": [
      "stddev(cn0_per_sv_dbhz) < uniformity_threshold and tracked_sv_count >= 6",
      "mean(cn0_per_sv_dbhz) > baseline_p99_cn0[receiver_id]",
      "abs(position_delta_m) > position_tolerance_m and asset.is_stationary == true",
      "abs(clock_offset_delta_s) > time_tolerance_s within window",
      "tracked_prn_set not_consistent_with almanac(time, location)",
      "disagreement_m(receiver_a, receiver_b) < known_separation_m * 0.5"
    ],
    "escalate_if_any": [
      "receiver feeds stratum-1 NTP or PTP grandmaster",
      "dependent_service in ['kerberos_kdc', 'pki_issuance', 'otp_validation', 'trading_timestamp', 'log_pipeline']",
      "two_or_more receivers affected concurrently"
    ],
    "action": "alert + fail_to_holdover_oscillator + freeze_time_dependent_issuance"
  },
  "notes": "Real constellations produce a C/N0 spread driven by elevation angle. A flat, uniformly strong C/N0 profile across all SVs is the classic single-transmitter signature.",
  "severity": "critical_when_escalated_else_high",
  "tags": ["gnss_spoofing", "no_clean_attack_mapping"]
}

```

7. Example Event Data

Documentation MAC addresses per RFC 7042 (00-00-5E-00-53-xx); IPv4 per RFC 5737.

```

WIPS sensor observation - evil twin
ts=2026-08-09T14:22:07Z sensor=SNS-08-N ssid="CORP-SECURE" bssid=00:00:5E:00:53:2F
  rssi=-38 channel=44 security=OPEN rfbom_match=NONE
ts=2026-08-09T14:22:07Z sensor=SNS-08-N ssid="CORP-SECURE" bssid=00:00:5E:00:53:11
  rssi=-71 channel=44 security=WPA3-802.1X rfbom_match=AP-0803 (baseline rssi -69 ±4)

-> Legitimate AP-0803 observed at baseline. Unknown BSSID at +33 dB stronger, security downgraded
    to OPEN. Three clients migrated within 4m.

WLC radio stats - denial vs. congestion
ap=AP-0311 band=2.4 ch=6 noise=-92dBm snr=31 frames/s=1840 retry=6% <- baseline
ap=AP-0311 band=2.4 ch=6 noise=-61dBm snr=4 frames/s=1795 retry=71% <- noise +31 dB,
                                     traffic flat: denial
ap=AP-0312 band=2.4 ch=6 noise=-63dBm snr=5 frames/s=1602 retry=68% <- same zone
ap=AP-0313 band=2.4 ch=6 noise=-60dBm snr=3 frames/s=1711 retry=74% <- same zone

GNSS receiver status - spoofing
receiver=GNSS-DC1-A fix=3D sv_tracked=11
  cn0_dbhz=[51,51,52,51,51,52,51,51,51,52,51] stddev=0.45 <- implausibly uniform
  pos_delta_m=0.4 clock_offset_delta_s=+41.7 <- 41s time jump, no motion
receiver=GNSS-DC1-B (separation 84 m) reported_separation_m=3.1 <- both receivers pulled together

Cellular modem diagnostic - managed endpoint
imei=<redacted> rat=LTE cell_id=0x1A2B3C cipher=EEA2 ->
imei=<redacted> rat=GSM cell_id=0x00FF01 cipher=A5/0 rxlev=-42
-> Forced downgrade LTE->GSM with null encryption, serving cell not in observed-cell history,
    signal implausibly strong for claimed macro position.

Sub-GHz spectrum sensor - implant beacon
freq=915.4MHz bw=125kHz burst_len=87ms interval=300.02s (cv=0.0007) rfbom_match=NONE
strongest_sensor=SNS-DC-02 (server room) est_position=(rack row C)

```

8. Investigation Steps

1. **Do not transmit.** Investigation is receive-only. Transmitting to probe, deauthenticate, or "test" a suspected rogue is at best evidence contamination and at worst unlawful - see Section 10 for the legal constraint. Every step below is passive unless the engagement authorization says otherwise in writing.
2. **Confirm the observation is real before it is an incident.** Check the sensor itself: calibration date, firmware, antenna condition, and whether a neighbouring sensor corroborates. A single sensor reporting an anomaly no other sensor sees is a sensor fault until proven otherwise.
3. **Reconcile against the RF-BOM.** Is the emitter genuinely unknown, or is it a known asset that was moved, re-flashed, or re-channelized by a change nobody logged? Pull the change record. In practice this resolves the clear majority of "rogue emitter" alerts.
4. **Establish physical position.** With three or more sensors, trilaterate from RSSI; with a directional antenna, bearing-and-walk. Position is the property the adversary cannot forge and the one that converts an alert into an action. Record the method and the uncertainty.
5. **Determine wired-side reachability.** For a suspected rogue AP, search switch CAM tables and DHCP leases for the device MAC and its OUI neighbours. An RF rogue that also touches the wire is a T1599 boundary bridge and escalates immediately.
6. **Characterize behavior over time.** Duty cycle, burst interval and its coefficient of variation, bandwidth, modulation family. Apply the D&R-08 periodicity analysis unchanged - an RF implant beacons for the same reason an implant on a host does.
7. **Identify the affected receivers, not just the emitter.** For denial and spoofing, the consequence is at the receiver. Enumerate what depends on the affected link or timing source before deciding severity: a jammed guest SSID and a jammed OT safety radio are not the same incident.

8. **Scope the compromise reachable through the RF path.** If an evil twin or rogue AP was available, treat every credential and session that transited it as exposed and hand off to D&R-01 / D&R-04 for the identity workstream and D&R-13 for lateral movement.
9. **Preserve evidence properly.** Timestamped I/Q captures where available, sensor observation logs, photographs and chain-of-custody for any recovered hardware, and the RF-BOM state at the time of detection. Physical devices go to the physical-evidence process - bag it, log it, do not power it on to "see what it is."
10. **Coordinate with physical security and facilities from the start.** RF incidents resolve in the physical world. Badge logs, camera footage, visitor records, and contractor schedules for the affected zone and time window are primary evidence here, not a nice-to-have.

9. False Positive Considerations

RF has the highest ambient false-positive rate of any medium in this library. Most of it is physics, not adversaries.

- **The neighbours.** Adjacent tenants, nearby residences, and passing vehicles produce a constant churn of unknown emitters. Without a baselined RF neighborhood, this alone will bury the queue.
- **2.4 GHz is a junkyard.** Microwave ovens, video senders, cordless phones, wireless cameras, and Bluetooth all share it. A noise-floor spike at lunchtime near a break room is an oven.
- **Multipath and body attenuation.** RSSI swings of 10 dB or more from a door opening, a rack being moved, or a room filling with people are routine. Position estimates carry real uncertainty; treat trilateration as a region, not a point.
- **Legitimate device churn.** Personal hotspots, BYOD, contractor equipment, demo gear, and IoT devices arriving through procurement paths that never touch IT.
- **Weather on outdoor links.** Rain fade on microwave and satellite links looks like degradation. It is distinguishable: fade attenuates the *carrier* (received level drops with error rate rising in proportion), while interference and jamming raise the *noise* with received level steady. Correlate with local weather data before escalating.
- **GNSS ionospheric and multipath effects.** Solar activity, urban canyons, and reflective surfaces degrade fixes without an adversary. The uniform-C/N₀ and independent-receiver-agreement tests exist precisely because they separate natural degradation from a single spoofing transmitter.
- **Maintenance windows.** AP firmware upgrades, channel-plan changes, antenna work, and building-automation commissioning all generate exactly the signatures above.

10. Tuning Guidance

- **Baseline first, alert second.** No RF rule ships before its site has a recorded baseline per sensor, per band, per hour-of-day. Every threshold in Section 6 is written as a deviation from that baseline for this reason - RF propagation is site-specific and any portable absolute number is wrong somewhere.
- **Weight physical implausibility above identity mismatch.** Identity fields are cheap to forge; position, timing, and signal-quality geometry are not. Scoring that leads with position produces far fewer false positives than scoring that leads with an unknown MAC.
- **Suppress the neighborhood as a maintained layer, not an ingest filter.** Same rule as D&R-08: keep the observations, suppress the alerts, and re-evaluate suppressions on a schedule. An adversary parking in the neighbours' RF space is a known tactic.
- **Require corroboration for single-sensor detections** in dense environments, and prefer multi-sensor concurrence for anything that triggers containment.

- **Tune GNSS uniformity thresholds against your own sky view.** A rooftop antenna with a clean horizon and a receiver in an urban canyon produce very different natural C/N₀ spreads.
- **Re-baseline after every physical change** - new walls, new racks, new APs, new neighbours, seasonal foliage on outdoor links. A stale RF baseline generates false positives indefinitely.
- **Track detection coverage explicitly.** Maintain, per band and per zone, whether you have sensing at all. An empty alert queue for a band you do not receive is not a clean result, and it should not be reported as one.

11. Response Actions

Legal constraint, stated before the actions because it governs them. Deliberate radio interference is unlawful in most jurisdictions - in the United States, 47 U.S.C. Section 333 prohibits willful interference with licensed radio communications, and the FCC prohibits the marketing, sale, and operation of jammers outright. Separately, the FCC has taken enforcement action against operators who used 802.11 deauthentication to block personal hotspots on their own premises. **"Jam the rogue" and "deauth it off the air" are not available responses.** They also destroy evidence and can disable safety-critical radio. Containment here is physical, wired, and policy-based. If your program believes it has an exception, get it in writing from counsel before an incident, not during one.

Immediate

- Preserve first: capture sensor observations, I/Q where available, and the current RF-BOM state before anything changes.
- Contain on the wire, not on the air. For a rogue AP with wired reachability, shut the switchport and quarantine the MAC - this is fully effective and entirely lawful.
- Move affected clients to a different band, channel, or SSID where the medium is contested.
- For GNSS spoofing: fail the affected receivers to holdover, and freeze time-dependent issuance (certificates, tokens, timestamps) until the time source is trusted again. **A wrong clock that is still being trusted does more damage than an outage.**
- Dispatch physical security to the estimated position. RF incidents are resolved by a person walking to a place.
- For OT/safety-critical denial, invoke the process-safety response path immediately and in parallel - do not serialize behind the security investigation.

Short-term

- Recover and forensically handle any physical device found; do not power it on outside a controlled environment.
- Rotate every credential and key that could have transited a compromised RF path, including PSKs for any network the rogue impersonated.
- Enforce 802.11w PMF and WPA3 where deauth abuse was observed - the attack is a configuration finding as much as an incident.
- Add the observed emitter characteristics to the RF-BOM as known-hostile, and hunt for the same signature across every other site.
- Review badge, camera, and visitor records for the zone and window; RF proximity implies physical presence.

Long-term

- Close the sensing gap the incident exposed. If the intrusion was found late or by accident, the finding is the coverage gap, not the emitter.

- Build and maintain the RF-BOM as a governed inventory with named owners, on the same footing as the CBOM (PB-01) and AI-BOM (PB-21).
- Eliminate unauthenticated and unencrypted radio from the estate on a dated plan: WPA3/802.1X for Wi-Fi, authenticated and encrypted LPWAN join, encryption on every point-to-point backhaul link.
- Architect on the assumption that RF is interceptable and jammable: **encrypt above the radio**, and ensure no safety-critical or availability-critical function depends on a single radio path with no wired or inertial fallback.
- Bring GNSS-derived time under the same discipline: multi-constellation, multi-frequency, signal authentication where available, disciplined holdover, and cross-checks against independent time sources.
- Include RF in physical-security zoning decisions - where the highest-consequence processing sits relative to the building perimeter is an RF control (Section 5.7).

12. Escalation Criteria

Escalate to incident when **any** of the following are true:

- A rogue emitter is confirmed to have wired-side reachability into the internal network (T1599) - this is a full intrusion, not an RF finding.
- An evil twin or rogue base station is confirmed **and** any client associated to it.
- GNSS spoofing is confirmed against a receiver feeding a time-dependent security service - KDC, PKI issuance, OTP validation, or the log pipeline that every other detection in this library depends on for correlation.
- Denial affects OT, safety, life-safety, or physical-security radio.
- An unauthorized emitter is localized inside a controlled or restricted zone - proximity implies physical access, which is its own incident regardless of what the radio was doing.
- Any RF implant is physically recovered, at any location.
- RF anomalies correlate in time with a physical-security event (forced door, unescorted visitor, after-hours badge) in the same zone.
- Sustained unexplained emission near a facility processing the organization's highest-consequence data.

13. Analyst Notes Template

```
Incident ID:
Detection Rule / Tier (0|1|2):
Detected At / Detected By (sensor IDs):
Band / Frequency / Channel:
Protocol / Modulation (observed):
Claimed Identity (SSID/BSSID/CellID/DevEUI):
RF-BOM Match:      none | known-asset | known-neighbour | known-hostile
Observed RSSI vs Baseline (per sensor):
Estimated Position / Method / Uncertainty:
Duty Cycle / Burst Interval / CV:
Intrusion Class:    presence | impersonation | denial | injection | reception-anomaly
Wired-Side Reachability: Y/N (switch/port/CAM evidence)
Affected Receivers / Dependent Services:
Clients or Sessions Exposed:
Physical Security Correlation (badge/camera/visitor):
Weather / Environmental Correlation (outdoor & GNSS only):
Evidence Preserved:  I/Q | sensor logs | photos | device (chain-of-custody ref)
Transmission Performed: NONE (record any exception + written authorization)
Containment Actions: wired | physical | policy (jamming/deauth NOT permitted - §11)
Credentials/Keys Rotated:
Coverage Gap Identified:
Outstanding Risks:
Recommendations:
Analyst:
```

14. Summary

Radio is the medium the SOC does not instrument, and an adversary on it bypasses every network control by never entering the network. Detection is geometric: presence, impersonation, denial, injection, and reception anomaly - scored with **physical position weighted above claimed identity**, because position is the one property an adversary cannot forge. Every threshold is a deviation from a locally recorded baseline; there are no portable absolute numbers in RF.

Two limits are structural and must be stated in any report built on this playbook. **Passive interception is undetectable in principle** - it is answered by encrypting above the radio, not by sensing. And **detection is bounded by the bands you actually receive** - an empty alert queue for an uninstrumented band is a coverage gap, not a clean result. Say which tier you are on.

Containment is physical, wired, and policy-based. Jamming and deauthentication are unlawful in most jurisdictions, destroy evidence, and can disable safety-critical radio. Shut the port, walk to the position, and rotate what was exposed.

GreyNOC - detection-engineering-first security operations.

SOURCE: TX-02-optical-nm-data-transmission-intrusion.md

TX-02 - Nanometer-Scale Optical Data Transmission, Reception & Intrusion Handling

TX-02 - Nanometer-Scale Optical Data Transmission, Reception & Intrusion Handling

1. Overview

Almost every byte the organization owns crosses a nanometer-wavelength carrier at some point. The data-center fabric, the campus backbone, the metro and long-haul links, the subsea cable, the inter-satellite crosslink - all of it is infrared light in glass or in vacuum, at wavelengths between roughly 800 and 1600 nm. It is the highest-bandwidth, longest-lived, least-monitored transmission medium in the estate, and in most organizations nobody in security has ever looked at it.

This playbook covers how data is **created on** and **recovered from** an optical carrier, and how to detect and respond to intrusions against that carrier.

Why this is a post-quantum problem, not just a plumbing problem. PB-02 treats harvest-now-decrypt-later as the dominant risk to long-lived confidentiality. A passive fiber tap is the single best harvesting position that exists. It sits upstream of every application control, it sees aggregate traffic rather than one session, it is silent, and - this is the part that matters - the ciphertext it collects stays collected. An adversary who taps a link in 2026 and stores the output is making a bet about 2036. The optical layer is where the HNDL adversary actually stands.

The two facts that structure everything below:

- A tap costs light.** Extracting a copy of an optical signal removes optical power from the original. It is physics, and it cannot be engineered away - only made small. Modern taps can operate at a fraction of a dB, comfortably inside the margin most links run with. That is why detection depends on a *tight local baseline*, not on a published threshold.
- Optical-layer detection is a tripwire, not a control.** Assume a competent tap can be placed below your detection floor. The control that survives that assumption is cryptographic: encrypt before the photons, with hybrid post-quantum key establishment, so a successful tap yields ciphertext with a shelf life longer than the adversary's patience. Section 9 is where the real defense lives. Section 7 and Section 8 tell you when someone tried.

Related: TX-01 (RF media - the other half of the physical layer), PB-02 (HNDL - this is the harvesting mechanism), PB-03 (hybrid TLS/KEM downgrade - what the tapped traffic had better be wrapped in), PB-09 (PQ VPN/IPsec/SSH - the tunnel over the tapped link), PB-25 (key management - what to rotate when a tap is confirmed), D&R-17 (exfiltration - optical is an alternate medium), D&R-19 (incident response).

2. Scope - the nanometer band

Wavelength	Band / name	Typical use	Security relevance
~380-750 nm	Visible	VLC / Li-Fi, status LEDs, displays	Covert channels; unintentional emission
~780-860 nm	Short-wave IR	Multimode short-reach, some FSO, IR remotes	Short-reach DC fabric; sensor injection

Wavelength	Band / name	Typical use	Security relevance
~1260-1360 nm	O-band (1310 nm nominal)	Single-mode short/medium reach, PON upstream	Campus and DC interconnect
~1460-1530 nm	S-band	Some PON, pump/monitoring	Out-of-band monitoring channels
~1530-1565 nm	C-band (1550 nm nominal)	DWDM metro/long-haul, subsea, coherent	The highest-value tap target in the estate
~1565-1625 nm	L-band	DWDM capacity extension, OTDR monitoring	Monitoring channels; out-of-band tap surface

DWDM channel plans follow the ITU-T G.694.1 grid (commonly 100 GHz or 50 GHz spacing, with flexible-grid deployments in newer systems). **The grid is a security fact, not just an engineering one:** a fiber carrying eighty channels can carry an eighty-first that nobody provisioned, and if your monitoring only watches the channels in the service inventory you will not see it.

Out of scope: X-ray and shorter (not a communications medium here), and the RF/microwave bands covered by TX-01.

3. How data is created on an optical carrier

Detection requires knowing which measurement changes when something is wrong, which requires knowing what the chain does. Transmit side:

1. **Framing and FEC.** Client data is framed (Ethernet, OTN) and forward error correction is added. FEC is the reason a link can degrade substantially before a single frame is lost - and therefore the reason **pre-FEC BER, not post-FEC error counts, is the sensitive early indicator**. Post-FEC errors mean the link is already failing; pre-FEC BER moves first.
2. **Electrical-to-optical conversion.** A laser (DFB or tunable) produces the carrier at an assigned wavelength. Direct modulation or an external modulator (Mach-Zehnder) imprints the data.
3. **Modulation format.** Short reach uses intensity modulation - NRZ/OOK, or PAM4 at higher rates - recovered by direct detection. Long reach uses coherent modulation (QPSK, 16QAM, and higher orders) encoding data in amplitude *and* phase across two polarizations, recovered by mixing with a local-oscillator laser. **Coherent links are materially harder to tap usefully:** the tapper needs to recover phase and polarization state, not merely detect power. Record the modulation format per link in the inventory - it changes the threat model.
4. **Multiplexing.** DWDM combines many wavelengths onto one fiber; ROADMs add, drop, and route individual wavelengths at intermediate sites. **The ROADM is the most under-appreciated security device in the network.** It can be configured to copy a wavelength to a monitor port. That is a legitimate operational feature and a perfect lawful-looking wiretap.
5. **Amplification.** EDFAs boost the aggregate signal without regeneration. They also add noise, which is why OSNR degrades along a path, and why an amplifier's gain-control behavior can mask a power loss introduced downstream - an important detection caveat in Section 7.
6. **Launch into the medium.** Single-mode fiber, multimode fiber, or free space (atmosphere or vacuum).

4. How data is recovered from an optical carrier

1. **Reception.** A photodiode (PIN or APD) for direct detection, or a coherent receiver front-end with a local oscillator and digital signal processing for phase-modulated formats.
2. **Recovered measurements** - this is the security telemetry, and the reason the receive side matters more to a detection engineer than the transmit side:

- **Rx optical power (dBm)** - falls when power is removed. The primary tap indicator.
- **OSNR (dB)** - optical signal-to-noise ratio. Falls with added noise or lost signal.
- **Pre-FEC BER** - moves before anything else user-visible does.
- **State of polarization (SOP) and polarization-dependent loss** - a physical disturbance to a fiber changes polarization state fast. **SOP transient monitoring is the most sensitive widely-available indicator of someone physically handling a cable**, and it is the closest thing the optical layer has to a burglar alarm.
- **Chromatic dispersion and differential group delay** compensation values - these track the physical path. A step change means the path changed.
- **Coherent DSP tap coefficients** on modern transponders - the equalizer's view of the channel. A discontinuity is a physical-path event.

1. **Path characterization telemetry** - not per-packet, but per-fiber:

- **OTDR** - launches pulses and maps reflective and loss events by distance. **An OTDR trace is a fingerprint of the physical route.** Diffing today's trace against a stored reference is the single highest-value optical detection available, because it localizes an event to a distance along the cable.
- **Distributed acoustic / vibration sensing (Φ -OTDR)** where deployed - detects digging, handling, and enclosure entry along the cable route.
- **Optical spectrum analysis** - shows which wavelengths are actually present, versus which ones were provisioned.

5. MITRE ATT&CK Mapping

Technique	ID	Matrix	Tactic
Hardware Additions	T1200	Enterprise	Initial Access
Network Sniffing	T1040	Enterprise	Credential Access, Discovery
Adversary-in-the-Middle	T1557	Enterprise	Collection, Credential Access
Supply Chain Compromise: Compromise Hardware Supply Chain	T1195.003	Enterprise	Initial Access
Exfiltration Over Other Network Medium	T1011	Enterprise	Exfiltration
Exfiltration Over Physical Medium	T1052	Enterprise	Exfiltration
Weaken Encryption	T1600	Enterprise	Defense Impairment
Network Denial of Service	T1498	Enterprise	Impact
Network Sniffing	T0842	ICS	Discovery
Adversary-in-the-Middle	T0830	ICS	Collection

Mapping discipline (CONVENTIONS Section 4). This table was verified against **ATT&CK v19.2** (Enterprise and ICS) on **2026-08-09**. **v19 retired the "Defense Evasion" tactic**, renaming TA0005 to **Stealth** and splitting out **TA0112 Defense Impairment**; T1600 landed on the Defense Impairment side, as did its sub-technique T1600.001 Reduce Key Space cited in PB-09. The ICS rows previously left as "verify against your ATT&CK version" are now filled in from the same check - ICS tactic placement is a **separate tactic set** from

Enterprise and still has to be re-verified on its own terms. Re-verify each row against the version your platform carries.

Deliberately unmapped. Per **CONVENTIONS** Section 4, these have no clean technique and are described rather than tagged: **passive fiber tapping as a distinct technique** (T1040 is the closest analogue but describes network-layer capture, not physical-medium extraction), **rogue-wavelength injection**, **ROADM monitor-port abuse**, **free-space optical beam interception**, and **optical injection into sensors**. Tag these with the Section 6 class name.

6. Intrusion Classes

These are descriptive classes for this playbook. They are deliberately **not** given a defect-class prefix under **CONVENTIONS** Section 8.1 - that registry belongs to the bug-bounty catalogs, and a prefix here would invite a triager to read a physical-medium event as an application defect.

6.1 Passive tap - bend coupler

A clip-on coupler bends the fiber past its critical angle, causing a fraction of the light to escape the core where a detector collects it. **Requires physical access to the cable but no cut, no splice, and no service interruption** - it can be applied and removed in minutes, and it is the reason "the link never went down" is not evidence that nothing happened.

Signature: a small step decrease in downstream Rx power; a rapid SOP transient at the moment of application and removal (handling the fiber is unavoidable); often an OTDR loss event at the tap distance. Magnitude depends entirely on the coupler and the operator's skill, and competent application can land inside a link's normal margin. **This is why the baseline must be tight and why SOP transients matter more than the steady-state power delta.**

6.2 Passive tap - splice and splitter

The fiber is cut and a splitter inserted, sending a permanent copy to the adversary. More reliable and higher-fidelity than a bend coupler, and permanent once installed.

Signature: an unavoidable service interruption at insertion (however brief - check for an unexplained link flap or protection switch, then check what the change record says was happening); a persistent step loss; a **new OTDR event at a fixed distance that was not in the reference trace**. The OTDR event is the durable evidence - the outage is a moment, the splice is forever.

6.3 ROADM / monitor-port abuse and optical-layer AiTM

No physical access required at all. An adversary with access to the optical management plane configures a wavelength copy to a monitor port, or routes a channel through a path they control. This is a **configuration** attack against a legitimate feature, and it produces almost no physical signature - the light is copied by design, not by damage.

Signature: unauthorized change to cross-connect, monitor-port, or optical-channel configuration; a wavelength appearing at a degree or port not in the service design; management-plane access outside change control.

Detection here is control-plane detection, not physics detection. Treat the optical management system as a Tier-0 privileged system with the same rigor as the network management plane - because that is what it is.

6.4 Rogue wavelength / optical injection

An adversary adds an unprovisioned wavelength to a shared fiber, using the organization's own infrastructure as an uncontrolled transport path - a covert channel that never touches a router. On unlit or dark-fiber pairs this can run indefinitely with no service impact whatsoever.

Signature: optical spectrum analysis shows a channel present that is not in the service inventory - the entire detection is *inventory versus reality*; unexplained EDFA gain-control activity as total input power changes; interference on adjacent provisioned channels.

6.5 Free-space optical and laser links

FSO, building-to-building laser links, and inter-satellite optical crosslinks trade the fiber's physical containment for a beam that exists in open space.

- **Off-axis interception.** A tight beam is genuinely hard to intercept, but atmospheric scattering, beam divergence at long range, and pointing jitter all put recoverable energy outside the intended aperture. Interception is passive and **not detectable at the receiver**.
- **Blinding and denial.** A high-power source aimed at the receive aperture saturates or damages it. Signature: receive power spikes or saturates while BER collapses - the inverse of an atmospheric fade, which drops power and error rate together.
- **Transmitter spoofing and beam hijack.** An adversary positioned within the receive cone presents a stronger signal. Signature: a step change in received power with no corresponding change in reported pointing/tracking error; an alignment lock achieved at an unexpected angle.
- **Environmental confound.** Scintillation, fog, rain, and thermal-gradient beam wander degrade FSO constantly. Any FSO detection that is not correlated against environmental data will produce a false positive every foggy morning. For orbital links, add pointing-acquisition-tracking telemetry and ephemeris as the correlation source.

6.6 Visible light, Li-Fi and IR

Short-range optical links in the visible and near-IR bands. The security property that matters: **containment is optical, not cryptographic**. "It doesn't leave the room" fails at windows, doorways, reflective surfaces, and glass partitions. Treat VLC/Li-Fi as a broadcast medium and encrypt it accordingly.

6.7 Optical air-gap covert channels

Both directions, both real, both demonstrated in published academic research:

- **Egress.** Data modulated onto a status LED, a display, a keyboard indicator, or an IR emitter, captured by a camera or photodiode with line of sight. This is T1052/T1011 - an exfiltration path that never touches a network interface, and therefore never appears in D&R-17.
- **Ingress.** Laser or modulated light injected into an optical sensor, camera, or scanner to inject commands or faults. Published research has demonstrated laser injection into MEMS microphones and optical sensors producing attacker-chosen input.

Detection is not primarily a telemetry problem here: it is line-of-sight control, physical siting, covering or disabling non-essential emitters on high-consequence systems, and treating optical sensors on those systems as untrusted input channels.

6.8 Transceiver and hardware supply chain

An optical module is a computer. It has firmware, an I²C management interface, and physical access to the signal before any host-side control sees it. A malicious or modified transceiver can copy traffic, weaken the link, or provide a persistent implant that survives host rebuild - T1195.003 and T1200.

Signature: module vendor/serial/firmware that does not match the procurement record; DDM/DOM telemetry inconsistent with the module's claimed type; unexpected firmware version or an unexplained in-service firmware change; modules sourced outside the approved supply chain. Reconcile module identity against procurement, not against what the module reports about itself - a module that lies about its traffic will lie about its part number.

6.9 Fiber cut and physical denial

The blunt instrument, and still the most common real-world optical incident. Signature: total loss of signal, OTDR event at a specific distance, protection switch.

The security-relevant subtlety: **a cut can be cover**. A brief unexplained outage on a link is the signature of splice-tap insertion (Section 6.2), and a cut that forces traffic onto a protection path may be intended to move traffic onto a route the adversary *has* tapped. Investigate unexplained optical outages as potential precursors, not just as availability events.

7. Detection Strategy

Telemetry tiers - be explicit about which one you are on, because it determines what an absence of alerts means.

- **Tier 0 - transponder and platform telemetry you already have.** Rx/Tx optical power, OSNR, pre-FEC BER, and DDM/DOM per optical module, polled continuously and baselined. Plus optical-management-plane configuration and audit logs, which are what actually catch Section 6.3. Detects: gross taps, splice insertion, rogue-wavelength effects on provisioned channels, ROADM abuse, denial. Does **not** detect: a well-executed bend tap inside margin, or anything passive in free space.
- **Tier 1 - path characterization.** OTDR baselines with scheduled re-trace and automated diff; optical spectrum analysis against the provisioned channel plan; SOP monitoring where the transponder exposes it. This is where Section 6.1 and Section 6.4 become reliably detectable, and where events become *localizable to a distance* - which is what converts an alert into a dispatch.
- **Tier 2 - continuous physical-layer sensing.** Distributed acoustic sensing on critical routes, in-line optical intrusion detection systems, monitored and alarmed cable enclosures, and continuous SOP transient analysis. This is the tier that detects the fiber being *handled*, before and independently of any measurable loss.

The four detection primitives:

1. **Power and quality deviation from a tight local baseline.** Rx power, OSNR, and pre-FEC BER are baselined per link, per direction, with the normal diurnal and seasonal drift modeled. The detection is a **step change** - a discontinuity - not an absolute threshold. Slow drift is aging and temperature; a step is an event.
2. **Path-fingerprint diff.** Today's OTDR trace against the stored reference. A new event, or a changed loss at an existing event, is a physical change to the route. This is the strongest single optical detection because it carries a distance.
3. **Provisioned-versus-observed inventory.** Which wavelengths are lit, which ports are cross-connected, which modules are installed - reconciled against the service design and the procurement record. Section 6.3, Section 6.4, and Section 6.8 are all inventory-reconciliation detections.
4. **Disturbance transients.** SOP transients and DAS events indicate handling. **These fire during the intrusion, not after it** - they are the only optical primitive with a chance of catching the adversary while they are still at the cable.

Two caveats that must appear in any report built on this playbook:

- **Amplifier gain control can mask a loss.** An EDFA in automatic-gain or constant-output mode will partially compensate for power removed upstream, flattening the very step you are watching for. Baseline and alert on the **pre-amplifier** measurement where the platform exposes it, and record amplifier control mode per span in the inventory.
- **A sufficiently careful tap is below the detection floor of Tier 0 and often Tier 1.** State your floor. Do not report "no evidence of tapping" when the accurate statement is "no event above our detection floor of X dB on

this link." The first is a fabrication under the house rule; the second is a finding.

8. Key Indicators

- Step decrease in Rx optical power on one direction of a link with no maintenance record.
- OSNR degradation without a matching change in span loss, weather, or amplifier state.
- Pre-FEC BER step increase while post-FEC traffic remains clean - **the earliest reliable indicator; treat a pre-FEC step as an event even when nothing user-visible has happened.**
- New or changed OTDR event versus the reference trace, especially at a distance that maps to an accessible location: a manhole, a riser, a patch panel, a building entrance, a cross-connect.
- SOP transient bursts on a link with no physical work scheduled - particularly outside working hours or in a location with no legitimate access.
- Brief unexplained link flap or protection switch followed by a persistent small loss increase - the splice-tap signature (Section 6.2).
- A wavelength present on the fiber that is not in the service inventory (Section 6.4).
- Optical cross-connect, monitor-port, or channel-routing change outside change control (Section 6.3).
- Transceiver vendor, serial, part number, or firmware inconsistent with the procurement record; unexplained in-service module firmware change (Section 6.8).
- Patch-panel, cross-connect enclosure, splice-closure, or manhole access without a work order.
- FSO: receive power spike with BER collapse (blinding); step power change with no pointing-error change (spoof); persistent degradation uncorrelated with weather.
- Unlit/dark fiber pairs showing optical activity.
- Any of the above on a link carrying long-shelf-life data - cross-reference the PB-02 HNDL prioritization directly. **The same physical event on a link carrying decade-lived secrets and on a guest-network uplink are not the same severity.**

9. Design Controls - where the actual defense lives

Detection is a tripwire. These controls are what make a successful tap a non-event, and they belong in the architecture before any of Section 7 is deployed.

- **Encrypt before the photons.** No plaintext on any optical span, including "internal" DCI, dark fiber between owned buildings, and anything a carrier calls a private circuit. Layer-2 MACsec (802.1AE), OTN-layer encryption, or Layer-3 IPsec - chosen per span and recorded per span.
- **Make it post-quantum, and specifically make the key establishment post-quantum.** A tapped span is harvested ciphertext (PB-02), so the relevant question is not whether it is encrypted today but whether it stays confidential for the data's full shelf life. Use hybrid key establishment - see CONVENTIONS Section 1 for ML-KEM parameter selection and CONVENTIONS Section 2 for hybrid named groups such as X25519MLKEM768 (0x11EC). **Where a link encryptor's key agreement is classical-only, that is a finding, and it is the finding that matters most in this playbook** - the physics is a tripwire, this is the control. Record it as a CBOM gap under PB-01 and prioritize it by Mosca margin under PB-14.
- **Prefer AES-256 on long-retention spans.** Grover halves symmetric strength; CONVENTIONS Section 1 is the reference.
- **Never carry key material in-band on the span it protects,** and never derive the link key from something the tap can also see.
- **Govern the optical management plane as a Tier-0 privileged system.** Section 6.3 is a configuration attack; MFA, change control, and audit logging on the optical NMS/SDN controller are the control. Alert on cross-

connect and monitor-port changes the same way you alert on domain-admin changes.

- **Physical protection proportional to consequence.** Alarmed and monitored enclosures, tamper- evident seals on patch panels and splice closures, conduit protection at building entrances, and documented route diversity so a cut cannot force traffic onto a single predictable path.
- **Procurement integrity for transceivers.** Approved-vendor sourcing, receiving inspection, serial reconciliation on install, and firmware version control. Treat an optical module as in-scope for supply-chain assurance (PB-27), not as a consumable.
- **On QKD, the GreyNOC position is explicit.** Quantum key distribution operates at this layer and is frequently proposed as the answer to optical tapping. It requires specialized hardware and trusted-node infrastructure, does not authenticate endpoints on its own, and multiple national authorities - NSA among them - do not recommend it for securing national security systems in place of standardized post-quantum cryptography. **PQC per CONVENTIONS Section 1 remains the GreyNOC default.** Where a QKD deployment exists, treat it as an additional optical asset with its own attack surface, not as a replacement for the controls above.

10. Sample Detection Logic (JSON-style)

```
{
  "rule_name": "Optical - Tap Signature by Step Loss and Quality Deviation",
  "description": "Detects the power/quality discontinuity characteristic of an inserted optical tap, distinguished from aging drift by requiring a step change.",
  "data_source": ["Transponder.OpticalPM", "Module.DDM", "NMS.ChangeRecord", "OpticalNMS.Amplifier"],
  "logic": {
    "window": "60m",
    "group_by": ["link_id", "direction"],
    "compute": {
      "rx_power_step_db": "step_change(rx_power_dbm, method='changepoint')",
      "osnr_step_db": "step_change(osnr_db, method='changepoint')",
      "prefec_ber_ratio": "prefec_ber / baseline_prefec_ber[link_id, direction]",
      "drift_rate_db_per_day": "linear_trend(rx_power_dbm, lookback='30d')"
    },
    "having": {
      "rx_power_step_db_lte": "-link_detection_floor_db",
      "step_duration_s_lte": 300,
      "is_step_not_drift": "abs(rx_power_step_db) > 5 * abs(drift_rate_db_per_day)"
    },
    "corroborate_any": [
      "osnr_step_db <= -link_osnr_floor_db",
      "prefec_ber_ratio >= link_prefec_multiplier",
      "sop_transient_count > baseline_p99 within 60m",
      "link_flap or protection_switch within preceding 24h"
    ],
    "suppress_if": [
      "NMS.ChangeRecord.active_maintenance(link_id) == true",
      "amplifier_control_mode in ['AGC', 'constant_output'] and pre_amp_measurement_unavailable == true"
    ]
  },
  "notes": [
    "link_detection_floor_db is derived per link from its own measured noise, NOT from a published constant. Record it; it is what bounds any 'no evidence of tapping' statement.",
    "The suppress_if amplifier clause is a KNOWN BLIND SPOT, not a clean result: AGC masks upstream loss. Route these links to the OTDR rule instead of silently dropping them."
  ],
  "severity": "high",
  "tags": ["T1040", "T1200", "optical_tap", "hdl_capture_point"]
}
```

```
{
  "rule_name": "Optical - OTDR Path Fingerprint Divergence",
  "description": "Differs the current OTDR trace against the stored reference to detect a physical change to the fiber route, localized to a distance.",
  "data_source": ["OTDR.Trace", "OTDR.ReferenceTrace", "Cable.RouteMap", "NMS.ChangeRecord"],
  "logic": {
    "schedule": "continuous_or_scheduled",
    "for_each": "fiber_span",
```

```

    "compute": {
      "new_events": "events(current) - events(reference)",
      "changed_events": "events where abs(loss_db_current - loss_db_reference) > event_tolerance_db",
      "event_location_m": "distance_along_span"
    },
    "trigger_any": [
      "count(new_events) > 0",
      "count(changed_events) > 0",
      "total_span_loss_db - reference_span_loss_db > span_tolerance_db"
    ],
    "enrich": {
      "physical_location": "RouteMap.lookup(event_location_m)",
      "accessibility": "RouteMap.access_class(event_location_m)"
    },
    "escalate_if_any": [
      "accessibility in ['manhole', 'riser', 'patch_panel', 'building_entrance', 'cross_connect', 'third_party_facility']",
      "no matching NMS.ChangeRecord within +/- 7d",
      "span carries data_class in PB02.hndl_priority_classes"
    ]
  },
  "notes": "The reference trace is the control. Re-baseline ONLY after authorized, documented work, and archive the superseded reference - a re-baseline performed on top of an intrusion permanently destroys the evidence.",
  "severity": "critical_when_escalated_else_high",
  "tags": ["T1200", "optical_path_change", "no_clean_attack_mapping"]
}

```

```

{
  "rule_name": "Optical - Unprovisioned Wavelength and Cross-Connect Divergence",
  "description": "Reconciles observed optical spectrum and cross-connect state against the service inventory to detect rogue wavelengths and monitor-port abuse.",
  "data_source": ["OSA.ChannelScan", "OpticalNMS.CrossConnect", "OpticalNMS.AuditLog", "Service.Inventory"],
  "logic": {
    "window": "1h",
    "trigger_any": [
      "observed_channel not in Service.Inventory.provisioned_channels[fiber_id]",
      "observed_channel_power_dbm > noise_threshold on unlit_or_dark_pair",
      "cross_connect_state != Service.Inventory.designed_cross_connect",
      "monitor_port_active and not in Service.Inventory.approved_monitor_ports",
      "wavelength present at degree/port not in service design"
    ],
    "escalate_if_any": [
      "OpticalNMS.AuditLog shows config change outside approved change window",
      "config change by identity without optical-plane authorization",
      "no audit-log entry corresponds to the observed state change",
      "affected channel carries data_class in PB02.hndl_priority_classes"
    ],
    "action": "alert + preserve_config_snapshot + do_not_revert_before_capture"
  },
  "notes": "An unauthorized monitor port with NO corresponding audit entry is worse than one with a bad entry: it implies the management plane itself is compromised. Escalate to D&R-19 before touching the configuration.",
  "severity": "critical",
  "tags": ["T1557", "T1040", "roadm_monitor_abuse", "no_clean_attack_mapping"]
}

```

```

{
  "rule_name": "Optical - FSO Beam Interference, Blinding or Spoof",
  "description": "Separates hostile optical events on free-space links from atmospheric degradation using the power/BER relationship and pointing telemetry.",
  "data_source": ["FSO.Terminal.PM", "FSO.PointingTelemetry", "Weather.Local", "Satellite.Ephemeris"],
  "logic": {
    "window": "15m",
    "for_each": "fso_link",
    "compute": {
      "rx_power_delta_db": "rx_power_dbm - baseline_rx_power_dbm[link_id, geometry]",
      "ber_delta": "prefec_ber / baseline_prefec_ber[link_id]",
      "pointing_error_delta": "tracking_error - baseline_tracking_error[link_id]"
    },
    "trigger_any": [
      "rx_power_delta_db > 0 and ber_delta > 1",
      "abs(rx_power_delta_db) > step_threshold_db and abs(pointing_error_delta) < pointing_tolerance",
      "alignment_lock_acquired_at_angle not in expected_geometry"
    ],
    "suppress_if": [

```

```

    "Weather.Local indicates fog/rain/scintillation consistent with observed fade",
    "Satellite.Ephemeris explains geometry change"
  ],
  "notes": "The discriminator: atmospheric fade drops received power AND raises BER together. Blinding RAISES received power while BER collapses. Spoofing changes received power with NO pointing-error change. Weather correlation is mandatory or this rule fires every foggy morning.",
  "severity": "high"
},
"tags": ["T1498", "T1557", "fso_interference", "no_clean_attack_mapping"]
}

```

11. Example Telemetry

IPv4 per RFC 5737; IPv6 per RFC 3849.

```

Transponder optical PM - bend-tap signature (link DCI-A-B, 1550.12 nm, C-band ch.34)
2026-08-09T02:10 rx=-8.42dBm osnr=21.7dB prefec_ber=2.1e-6 sop_transients=0
2026-08-09T02:15 rx=-8.44dBm osnr=21.7dB prefec_ber=2.2e-6 sop_transients=0
2026-08-09T02:41 rx=-8.43dBm osnr=21.6dB prefec_ber=2.1e-6 sop_transients=47 <- handling
2026-08-09T02:42 rx=-8.91dBm osnr=20.9dB prefec_ber=9.7e-6 sop_transients=112 <- step
2026-08-09T02:47 rx=-8.90dBm osnr=20.9dB prefec_ber=9.9e-6 sop_transients=3
2026-08-09T03:00 rx=-8.90dBm osnr=20.9dB prefec_ber=9.8e-6 sop_transients=0 <- new steady state
-> 0.47 dB step in 60s. 30-day drift rate 0.004 dB/day: this is 117x the drift, i.e. a step.
Post-FEC traffic clean throughout. No change record. link_detection_floor_db = 0.25.

```

OTDR trace diff - span MAN-04 (reference 2026-05-14)

event	distance_m	type	loss_dB_ref	loss_dB_now	delta
E1	0.0	connector	0.31	0.32	+0.01
E2	412.6	splice	0.06	0.06	0.00
E3	1187.3	connector	0.28	0.29	+0.01
E4	2043.9	-- ABSENT --	--	0.44	NEW <<<
E5	3990.1	end	--	--	--

RouteMap.lookup(2043.9) = "Manhole MH-17, 3rd & Vine, access_class=street_manhole"

ChangeRecord(+/-7d) = NONE

Optical spectrum analysis - fiber DARK-PAIR-07 (inventory: unlit)

```

1529.55nm -48.1 dBm (noise)
1550.92nm -14.6 dBm <<< channel present on a pair with no provisioned service
1561.42nm -47.9 dBm (noise)

```

Optical NMS audit - monitor-port abuse

```

2026-08-09T01:58Z user=svc-optical-ro action=cross_connect_add
src=deg2/ch34 dst=mon-port-3 result=SUCCESS change_ticket=<none>
-> Read-only service account performed a write. No ticket. Monitor port not in approved list.

```

FSO terminal - blinding vs. fade (link ROOF-N to ROOF-S)

```

baseline rx=-31.2dBm prefec_ber=4e-7 tracking_err=0.8urad weather=clear
2026-08-09T11:02 rx=-38.7dBm prefec_ber=6e-5 tracking_err=0.9urad weather=fog <- fade (both worsen)
2026-08-09T15:40 rx=-19.4dBm prefec_ber=3e-3 tracking_err=0.8urad weather=clear <- BLINDING
                                                                    (power UP, BER UP)

```

Transceiver reconciliation

```

port=Et1/49 reported: vendor=<V> pn=<P> sn=XXA1934 fw=3.2.1
procurement: vendor=<V> pn=<P> sn=XXA1934 fw=3.1.0 (shipped)
-> In-service firmware change with no maintenance record. Module holds pre-encryption signal path.

```

12. Investigation Steps

- 1. Do not re-baseline, do not revert, do not clean the connector.** The reference OTDR trace, the current optical PM history, and the current cross-connect configuration are the evidence. A re-baseline performed on top of an intrusion destroys it permanently and irreversibly. Snapshot everything before any remediation touches the link.
- 2. Check the change record first.** Optical events have mundane causes at a high rate: maintenance, connector cleaning, re-patching, splice repair, module replacement, construction along the route. Pull work orders,

carrier maintenance notices, and contractor schedules for the link and the window. This resolves most alerts and it resolves them fast.

3. **Confirm the step is a step.** Compare the magnitude against the link's own 30-90 day drift rate. Aging, temperature, and connector degradation produce gradual change; a tap produces a discontinuity. Compute the ratio and put it in the report - it is the difference between an event and a maintenance ticket.
4. **Localize with OTDR and map the distance to a physical place.** This is the decisive step. A distance becomes a manhole, a riser, a patch panel, a building entrance, a carrier cross-connect, a colocation cage. Record the access class of that location, because it determines both who could have done it and how urgent the dispatch is.
5. **Correlate with physical access.** Badge logs, camera footage, work orders, visitor records, and carrier or landlord access logs for that location and window. For third-party facilities, this means a formal request - start it immediately; it is the long pole.
6. **Check the direction and the position in the path.** Which direction lost power, and where the loss sits relative to amplifiers, tells you where in the span to look and whether AGC could have masked a larger upstream loss than you measured.
7. **Reconcile the optical inventory end to end.** Provisioned wavelengths versus observed spectrum; designed cross-connects versus running configuration; procurement records versus installed module serials and firmware. Rogue wavelengths, ROADM abuse, and malicious transceivers are all found here and nowhere else.
8. **For any management-plane involvement, pivot to a full intrusion investigation.** An unauthorized cross-connect means someone had access to the optical NMS. That is a compromised privileged system - hand off to D&R-19 and treat the optical event as one symptom, not the incident.
9. **Determine exposure, and determine it cryptographically.** Enumerate every service, tunnel, and data class carried on the affected wavelength for the entire period since the last verified clean baseline - **not since detection**. Then answer the question that actually determines severity: *was the traffic on that span encrypted, with what key establishment, and does its confidentiality need to survive a cryptanalytically relevant quantum computer?* Ciphertext under hybrid PQ key establishment is a contained incident. Plaintext, or ciphertext under classical-only key exchange carrying decade-lived secrets, is an HNDL exposure - scope it under PB-02 and escalate accordingly.
10. **Assume the exposure window is longer than the detection window.** A bend tap leaves nothing behind once removed. The defensible statement is bounded by your last verified clean measurement, and that is the window you must report.
11. **Preserve physical evidence properly.** If a device is found, photograph in place, document chain of custody, and hand to the physical-evidence process. Do not power it on outside a controlled environment.

13. False Positive Considerations

Most optical anomalies are maintenance and physics. Expect this to dominate the queue.

- **Scheduled and unscheduled maintenance** - splice repair, re-patching, module replacement, carrier work on leased spans. Carrier maintenance notices frequently arrive late or not at all; chase them rather than escalating.
- **Connector contamination and cleaning.** A dirty connector adds loss gradually; cleaning it removes loss suddenly. **A sudden loss improvement is a change record you are missing, not a clean result.**
- **Temperature and seasonal drift.** Aerial fiber, building risers, and outside plant all show diurnal and seasonal variation. Model it into the baseline or it will fire daily.

- **Component aging.** Laser output declines over life; receiver sensitivity degrades. Gradual, not step - which is exactly what the step-versus-drift test in Section 10 separates.
- **Amplifier gain transients** during channel add/drop operations, which are legitimate service activity.
- **Protection switching** moving traffic to a path with different loss characteristics. The new path has a different baseline; alerting against the old one is a false positive.
- **Construction and vibration near the route** producing SOP and DAS events with no tap. This is the main SOP false-positive source; correlate with known works.
- **FSO weather** - fog, rain, snow, scintillation, and thermal beam wander. Weather correlation is mandatory for any FSO rule.
- **Orbital-link geometry** - legitimate pointing and handover events on inter-satellite links. Correlate against ephemeris.

14. Tuning Guidance

- **The baseline is the detection.** Nothing in this playbook works without a per-link, per- direction, drift-modeled baseline of Rx power, OSNR, and pre-FEC BER, plus a stored OTDR reference trace per span. Build these before writing a single rule.
- **Record `link_detection_floor_db` per link and treat it as a first-class output**, not an internal parameter. It bounds every statement the program can make about tapping on that link, and it belongs in the analyst notes and in any assurance report.
- **Alert on steps, not thresholds.** Use changepoint detection with the drift-ratio test. Absolute-threshold alerting on optical power produces alarm fatigue and misses small taps.
- **Lead with pre-FEC BER.** It moves before post-FEC errors, before traffic impact, and often before a power step is unambiguous.
- **Prioritize by data class, not by link.** Use the PB-02 HNDL prioritization to decide which spans get Tier-1 and Tier-2 sensing. Not every fiber warrants an OTDR program; the ones carrying decade-lived confidentiality do.
- **Re-baseline only after authorized documented work, and archive the superseded reference.** Never let an automated process silently re-baseline.
- **Treat AGC-masked links as an explicit coverage gap** with a named owner and a compensating control (OTDR or SOP), not as links that simply never alert.
- **Reconcile inventory on a schedule, not only on alert.** Rogue wavelengths and unauthorized cross-connects are found by periodic reconciliation; a rogue λ on a dark pair generates no service impact and will never alert on its own.

15. Response Actions

Immediate

- Preserve before you fix: snapshot optical PM history, current and reference OTDR traces, spectrum scan, cross-connect configuration, module inventory, and NMS audit logs. **Remediation destroys optical evidence - capture first, without exception.**
- Do not revert an unauthorized cross-connect before capturing it; the configuration is the evidence and reverting may tip the adversary.
- Determine what the affected wavelength carries and how it is protected. This determines everything downstream.

- Dispatch to the localized physical position; engage facilities, the carrier, or the colocation provider as the location requires.
- If safe and available, move critical traffic to a diverse path - but confirm the alternate path is not the one the adversary intended to force you onto (Section 6.9).
- For confirmed management-plane compromise, invoke **D&R-19** and treat the optical NMS as a compromised privileged system.

Short-term

- **Rotate keys on the assumption the tap succeeded.** Every link encryptor key, every session key negotiated over the affected span, and every long-lived secret that transited it since the last verified clean baseline. **PB-25** governs the rotation and rewrap workflow.
- Where key establishment on the affected span was classical-only, **treat all traffic carried since the last clean baseline as harvested** and scope it under **PB-02**. This is the HNDL case made concrete: the ciphertext is gone, and its confidentiality now depends entirely on the key exchange that protected it.
- Re-verify the physical path end to end, including patch panels, cross-connects, splice closures, and any third-party facility on the route.
- Reconcile every transceiver on the affected path against procurement; replace anything that does not reconcile.
- Sweep for the same signature across every other span - a tap found on one link is a reason to re-trace the rest, and organizations routinely find the second one this way.
- Notify the carrier or facility provider where the event localizes to their infrastructure, and preserve the right to inspect.

Long-term

- Close the encryption gap the incident exposed. **Any span found carrying plaintext or classical-only key establishment is the primary finding of the incident**, regardless of whether the tap is confirmed - the tap is the demonstration, the gap is the vulnerability. Migrate to hybrid PQ key establishment per **CONVENTIONS Section 1/Section 2**, and record it in the CBOM (**PB-01**) with a Mosca-margin-driven date (**PB-14**).
- Raise sensing tier on spans carrying HNDL-priority data: OTDR baselining with automated diff at minimum, DAS on critical routes where the consequence justifies it.
- Bring the optical management plane fully under privileged-access management with alerting on cross-connect and monitor-port changes.
- Harden the physical route: alarmed enclosures, tamper-evident seals, conduit protection, and documented, genuinely diverse routing.
- Add optical modules to supply-chain assurance (**PB-27**) with serial reconciliation at install.
- Add the optical plane to the CBOM as a first-class transport surface, so the next crypto inventory does not stop at the application layer.

16. Escalation Criteria

Escalate to incident when **any** of the following are true:

- An OTDR event appears that is absent from the reference trace with no corresponding change record - regardless of magnitude.
- A step power or OSNR loss is confirmed as a step (not drift) with no maintenance explanation.
- An unprovisioned wavelength is observed on any fiber, lit or dark.

- Any unauthorized optical cross-connect or monitor-port configuration is found - and treat it as **critical** where no corresponding audit-log entry exists, because that implies the management plane itself is compromised.
- A transceiver fails procurement reconciliation on serial or firmware.
- The affected span carried **plaintext**, or ciphertext under **classical-only key establishment**, and the data class has a shelf life extending past the organization's quantum risk horizon. This is an HNDL exposure under PB-02 and escalates on its own merits, whether or not the tap is ever confirmed.
- SOP or DAS disturbance events occur at a location with no authorized access, particularly out-of-hours.
- FSO blinding or spoofing signature confirmed against weather and ephemeris.
- An optical event correlates with a physical-security event on the same route.
- An unexplained optical outage occurs on a link carrying high-consequence data - investigate as a possible splice-tap insertion or path-forcing precursor (Section 6.9), not as an availability ticket.

17. Analyst Notes Template

```

Incident ID:
Detection Rule / Telemetry Tier (0|1|2):
Detected At / Detected By:
Link / Span ID / Direction:
Wavelength (nm) / DWDM Channel / Modulation Format:
Medium:          SMF | MMF | FSO | ISL | VLC/IR
Intrusion Class:  bend-tap | splice-tap | ROADM/monitor | rogue-lambda | FSO |
                  air-gap-optical | transceiver-supply-chain | physical-denial

--- Measurements ---
Rx Power: baseline ____ dBm  observed ____ dBm  step ____ dB
OSNR:      baseline ____ dB   observed ____ dB
Pre-FEC BER: baseline ____  observed ____  ratio ____
30-90d drift rate ____ dB/day  step:drift ratio ____  (step confirmed? Y/N)
link_detection_floor_db: ____  <-- BOUNDS EVERY "no evidence" STATEMENT IN THIS REPORT
SOP transients / DAS events: ____
Amplifier control mode / AGC masking possible: ____ / Y/N

--- Localization ---
OTDR reference date / new or changed event / distance: ____ / ____ / ____ m
Physical location / access class: ____ / ____
Third-party facility involved: ____
Physical access correlation (badge/camera/work order/carrier): ____
Weather / ephemeris correlation (FSO & ISL only): ____

--- Inventory reconciliation ---
Provisioned vs observed wavelengths: ____
Cross-connect design vs running: ____
Monitor ports (approved vs active): ____
Transceiver serial/firmware vs procurement: ____
NMS audit entry present for observed change: Y/N  <-- N = management-plane compromise

--- Exposure ---
Services / data classes on affected wavelength: ____
Encryption in force on span: none | MACsec | OTN | IPsec | ____
Key establishment: classical-only | hybrid PQ (____)  <-- THE severity determinant
Data shelf life vs quantum risk horizon (PB-14 Mosca): ____
Last verified clean baseline: ____  Exposure window: ____
HNDL scoping required (PB-02): Y/N

--- Handling ---
Evidence preserved before remediation: Y/N (list)
Keys rotated / rewrap scope (PB-25): ____
Containment actions:
Coverage gap identified:
Outstanding Risks:
Recommendations:
Analyst:

```

18. Summary

Data is created at the nanometer scale by imprinting bits on a laser carrier - intensity-modulated for short reach, coherent phase-and-polarization modulated for long reach - multiplexed onto a DWDM grid, amplified, and routed through ROADMs. It is recovered by a photodiode or a coherent receiver whose telemetry - Rx power, OSNR, pre-FEC BER, state of polarization - *is* the security instrumentation for the medium.

Intrusion detection rests on four primitives: **step deviation** from a tight local baseline, **OTDR path-fingerprint diff** (the only primitive that yields a distance, and therefore a dispatch), **provisioned-versus-observed inventory reconciliation** (which is how rogue wavelengths, ROADM monitor abuse, and malicious transceivers are found), and **disturbance transients** (the only primitive that fires while the adversary is still at the cable). Alert on steps rather than thresholds, lead with pre-FEC BER, and preserve the reference trace as evidence - a re-baseline over an intrusion erases it permanently.

Two limits must be stated in every report. **Amplifier gain control can mask upstream loss** - such links are a named coverage gap, not quiet links. And **a competent tap can sit below the detection floor**, so the honest finding is "no event above our floor of X dB," never "no evidence of tapping."

Which is why the response is cryptographic before it is physical. Assume the tap succeeded: rotate keys, scope the exposure from the last verified clean baseline rather than from detection, and treat any span running plaintext or classical-only key establishment as the primary finding. Optical monitoring tells you someone was at the cable. **Hybrid post-quantum key establishment is what makes it not matter.**

GreyNOC - detection-engineering-first security operations.

SOURCE: CONVENTIONS.md

CONVENTIONS

Shared reference for the GreyNOC AI · PQ · E2EE playbook collection. Cited values reflect the standards landscape as of mid-2026; verify against current NIST / IETF publications before operational use, because this space is still moving.

1. Algorithm reference

Key encapsulation (KEM) - replaces RSA / ECDH key exchange

Standard	Name	Basis	Parameter sets	Notes
FIPS 203	ML-KEM (Kyber)	Module-LWE lattice	512 / 768 / 1024	Primary KEM. ML-KEM-768 ciphertext ~1088 B
In development (final expected 2027)	HQC	Code-based (quasi-cyclic)	TBD	Backup KEM selected Mar 2025; not yet a standard ; diversity hedge vs. lattice break

Signatures - replaces RSA / ECDSA / EdDSA

Standard	Name	Basis	Parameter sets	Notes
FIPS 204	ML-DSA (Dilithium)	Module-LWE/SIS lattice	44 / 65 / 87	ML-DSA-65 is the recommended default. Sig ~3309 B, pubkey ~1952 B
FIPS 205	SLH-DSA (SPHINCS+)	Hash-based	many	Conservative backup; large sigs (~7.8-49.9 KB)
FIPS 206 (in development)	FN-DSA (Falcon)	NTRU lattice + FFT	-	Selected algorithm and expected standard name; do not claim FIPS 206 compliance until final publication
SP 800-208	LMS / XMSS	Hash-based, stateful	-	Use now for firmware/code-signing per NSA guidance

Security levels: L1 ~ AES-128, L3 ~ AES-192, L5 ~ AES-256. Grover halves symmetric strength, so for long-retention data prefer **AES-256** and **SHA-384** over AES-128/SHA-256.

Naming discipline. Use standardized names (ML-KEM, ML-DSA, SLH-DSA) in all reports, tickets, and findings. Submission names (Kyber, Dilithium, SPHINCS+) are acceptable only as parenthetical aliases. For Falcon, write **Falcon / expected FN-DSA (FIPS 206 in development)** until FIPS 206 is final. Never represent a selected algorithm, draft, or reserved standard name as a completed compliance target.

2. Hybrid TLS named groups

Hybrid = classical + PQ KEM run together; an attacker must break **both** to recover the session key. Watch for these in ClientHello / ServerHello supported_groups / key_share :

NamedGroup	Value	Composition	Client key share
X25519MLKEM768	0x11EC	X25519 + ML-KEM-768	~1216 B
SecP256r1MLKEM768	(impl-specific)	P-256 + ML-KEM-768	-
SecP384r1MLKEM1024	(impl-specific)	P-384 + ML-KEM-1024	-

Production support: Chrome/BoringSSL, Firefox, Cloudflare, Akamai (default Feb 2026), AWS, OpenSSL 3.5+ (native), wolfSSL, rustls, Botan. `oqs-provider` (liboqs) is the reference experimentation provider and is **not** FIPS-validated - flag it if seen in a production path.

Quick manual check (read-only inspection of a host you are authorized to test):

```

openssl s_client -connect HOST:443 -groups X25519MLKEM768 -tls1_3 </dev/null 2>/dev/null \
| grep -i "Negotiated\|group"
    
```

3. E2EE protocol reference

System	PQ status	Construction	Notes
Signal PQXDH	PQ initial key establishment (Level 2)	X25519 + ML-KEM, Double Ratchet	Sept 2023; PQ at handshake only
iMessage PQ3	PQ initial + ongoing rekey (Level 3)	hybrid ECDH + ML-KEM, periodic PQ rekey (~every 50 epochs)	Uses signatures over MAC; Secure Enclave signing
MLS (RFC 9420)	classical baseline; PQ ciphersuites emerging	TreeKEM group key agreement	Group E2EE; watch ciphersuite negotiation

Open problem to keep in scope: PQ *authentication* ("Level 4") is not solved at scale by PQXDH or PQ3 - both still authenticate with classical primitives. Key-transparency systems (iMessage Contact Key Verification, WhatsApp Auditable Key Directory) are the current mitigations against key-substitution MITM; monitoring them is a detection opportunity (PB-04).

4. MITRE mapping conventions

- ATT&CK** is referenced as **name + ID + content version**, on the same terms as ATLAS below - e.g. *Weaken Encryption* (T1600 , ATT&CK Enterprise v19.2). **Technique names, technique IDs, and tactic assignments all change between versions**, so none of the three is cited bare, and every playbook carrying an ATT&CK mapping table states the version it was verified against in a *Mapping discipline* note directly under the table.
- The tables in this library are verified against **ATT&CK Enterprise v19.2** (site content v19.2, website v5.0.0), checked against `attack.mitre.org` on **2026-08-09**.
- v19 retired the "Defense Evasion" tactic.** TA0005 was renamed to **Stealth**, and a new **TA0112 Defense Impairment** was split out of it. Concealment stayed on the Stealth side (T1027 , T1070 , T1620 , T1564.008 , T1134 , T1542.001 , T1078); tampering with the controls themselves moved to Defense Impairment (T1553 and its sub-techniques, T1556 , T1484 , T1599 , T1600 , T1601). **Neither substitution is automatic** - see the next two bullets. Any artifact still carrying a "Defense Evasion" tag is mapped against a pre-v19 collection and must be re-mapped.
- v19 renumbered and renamed techniques, not just tactics.** T1562 `Impair Defenses` no longer exists: the concept was elevated to the Defense Impairment *tactic*, and its tool-tampering sub-technique was promoted to the top-level **T1685 Disable or Modify Tools**. T1070.001 `Indicator Removal: Clear Windows Event`

Logs was renumbered and reparented to **T1685.005 Disable or Modify Tools: Clear Windows Event Logs** (parent T1070 Indicator Removal still exists, under Stealth). T1484 was renamed **Domain or Tenant Policy Modification**, and T1484.002 to **Trust Modification**. attack.mitre.org redirects a retired ID to its replacement - that redirect is the authoritative remapping.

- *v19 also removed a tactic from some techniques rather than renaming it. **T1550.001, T1550.002, and T1550.003 are now Lateral Movement only***; rewriting their old "Defense Evasion / Lateral Movement" tag as "Stealth / ..." would be wrong. Verify each technique individually; never sweep a rename across a table.
- A table may cite a **subset** of a technique's tactics - the one operative for that playbook - provided the cited tactic is still assigned in the stated version. Say so in the note so the subset is not later "corrected" into an error.
- ICS techniques (T0xxx) use the ICS tactic set, which is distinct from Enterprise; cite the ICS tactic and re-verify separately.
- **ATLAS** is referenced as **name + ID + collection version** - e.g. *LLM Prompt Injection* (AML.T0051, ATLAS 2026.06). **Both the ID and the name are versioned and both do change**, so neither is cited bare: the collection version is what makes a citation checkable. Any playbook citing ATLAS states the collection version it was written against, and a reader re-maps to whatever their platform carries at deployment time.
- The AI playbooks in this library (PB-15-PB-20) are written against the official [mitre-atlas/atlas-data](#) collection **version 2026.06** (format-version 6.0.0, collection modified-date 2026-05-27, published 2026-06-30). Verified from `dist/v6/ATLAS-2026.06.yaml`: **16 tactics** and **173 techniques** (103 parent techniques + 70 sub-techniques), of which **114 list Agentic AI** and **92 list Generative AI** among their platforms - every Generative AI technique also carries Agentic AI, so 114 is the union, not the sum.
- **2026.06 renamed most ML techniques to AI, and renamed some outright.** Cite the 2026.06 name: AML.T0010 is *AI Supply Chain Compromise*, AML.T0018 is *Manipulate AI Model* (formerly *Backdoor ML Model*), AML.T0053 is *AI Agent Tool Invocation* (formerly *LLM Plugin Compromise*), and AML.T0014 is *Discover AI Model Family* - **not** the older *Discover ML Artifacts*, which is a different concept. Every ATLAS-citing playbook in this library has been re-mapped to the 2026.06 names and states the collection it was written against; treat any artifact that does neither as pre-2026.06 and re-map it before reuse rather than assuming the names match.
- **2026.06 added purpose-built RAG and agentic techniques - map to them instead of forcing an older tag** (Section 4's "say so rather than forcing a tag" cuts both ways). The ones this collection leans on: *RAG Poisoning* (AML.T0070), *False RAG Entry Injection* (AML.T0071), *Data from AI Services: RAG Databases* (AML.T0085.000), *AI Agent Context Poisoning* (AML.T0080, with .000 Memory), *AI Agent Tool Poisoning* (AML.T0110), *Poisoned AI Agent Tool* (AML.T0011.002), *Publish Poisoned Models* (AML.T0058), *AI Supply Chain Rug Pull* (AML.T0109), *LLM Prompt Obfuscation* (AML.T0068), *LLM Prompt Self-Replication* (AML.T0061), and *Cost Harvesting: Agentic Resource Consumption* (AML.T0034.002). In particular, AML.T0031 *Erode AI Model Integrity* is **not** the tag for corpus or memory poisoning - it describes degrading the model itself, and does not apply where the model is untouched.
- ATLAS carries a `maturity` field per technique (Realized, Demonstrated, Feasible; in 2026.06 the split is 64 / 90 / 19). Quote it when severity or plausibility is in question: a technique marked *Feasible* has not been observed in the wild, and a report that implies otherwise is fabricating impact.
- Where no clean mapping exists (much PQ-migration-defect work is pre-ATT&CK), the playbook says so rather than forcing a tag.

5. Example-data conventions

- Network examples use **RFC 5737** (192.0.2.0/24, 198.51.100.0/24, 203.0.113.0/24) and **RFC 3849** (2001:db8::/32) documentation address space.

- Identities, domains, and tokens in examples are illustrative and non-attributable.
- Detection logic is **JSON-shaped pseudocode**, not a SIEM query. Translate per platform.
- **Cross-reference notation.** The library holds **three independently numbered collections**, so a bare number is never a valid citation. `PB-NN` always means *this* collection (AI · Post-Quantum · E2EE). A playbook in the Detection & Response collection is written `D&R-NN` - e.g. `D&R-09` is AI / Automated Agent Abuse, while `PB-09` is PQ VPN, IPsec & SSH. A playbook in the Transmission & Physical Layer collection is written `TX-NN` - `TX-01` is RF & radio spectrum, `TX-02` is nanometer-scale optical. Never cite a bare number across collections.

6. Rules of engagement (binds all bug-bounty playbooks)

Authorized testing only. GreyNOC operates as the submitting firm under platform programs (e.g., HackerOne / YesWeHack) or direct written engagement.

1. **No activity without scope on file.** A signed SOW or an in-scope, in-policy bug-bounty program is a precondition. Out-of-scope assets, third-party dependencies not named in scope, and chained pivots beyond the authorized boundary are prohibited.
2. **Least-impact testing.** Prefer read-only inspection (handshake/cert/token observation) over anything state-changing. No DoS, no data exfiltration beyond minimal proof, no persistence, no lateral movement unless explicitly authorized.
3. **No fabrication.** Every reported finding must be independently reproducible from the evidence in the report. No speculative severity, no invented impact, no copied CVE text passed off as original analysis. If you cannot reproduce it, it is not a finding.
4. **Data handling.** Capture the minimum proof necessary. Never retain third-party PII, secrets, or message plaintext beyond what the program permits; redact in reports.
5. **Coordinated disclosure.** Follow the program's disclosure timeline. Do not publicize before remediation/authorization.
6. **Stop conditions.** On encountering evidence of a prior real-world compromise, customer PII at rest, or anything outside scope - stop, preserve, and escalate to the program owner.

7. AI-system testing addendum (binds Playbooks 15-20)

Section 6 applies in full. AI targets add failure modes that generic web ROE does not cover, so these rules are additive and non-negotiable for any engagement against a model, an agent, an AI-backed application, or the infrastructure serving them.

1. **Classify before you submit: security defect vs. model behavior.** Most AI programs scope *security* defects - broken authn/authz, injection that crosses a trust boundary, data exposure, tenancy failures, infrastructure compromise - and explicitly route *model behavior* (jailbreaks yielding disallowed content, hallucination, bias, refusal bypass) to a separate model-safety channel. A jailbreak is a **security** finding only when it produces a concrete security consequence: an unauthorized tool invocation, access to data the tester was not entitled to, a privilege change, or code execution. Submitting content-policy bypasses to a security queue is the fastest way to lose program standing.
2. **Never generate genuinely harmful content as proof.** Demonstrate the *control failure*, not the payload. Use an inert canary, a policy-marker string, or a benign no-op tool call. If proving a finding would require producing actually weaponizable material, stop and report the control gap with the boundary evidence already in hand.
3. **Self-scoped tenancy.** Test with your own accounts, tenant, documents, keys, and agents. Cross-tenant and cross-user claims must be demonstrated between **two tenants you control**; never between yours and a real customer's.

4. **Canary discipline.** Plant uniquely identifiable inert markers - format `GNBB-CANARY-<uuid4>` - so retrieval, leakage, and propagation claims are provable and attributable, and so the target's defenders can separate your traffic from a real adversary's.
5. **Denial-of-wallet is a real harm.** Inference is metered and shared. Stay inside documented rate limits, cap total requests up front, never run volumetric fuzzing, and demonstrate a missing consumption control with the **minimum** request count that shows it - not by actually exhausting the quota, the context window, or the GPU pool.
6. **Stochastic reproducibility.** Model output is nondeterministic; one successful prompt is not a finding. Every AI finding records model and version string, sampling parameters (temperature / top-p / seed where settable), trial count, success count, observed success rate with its confidence interval, and timestamps. **The GreyNOC bar is ≥ 2 successes from a clean context across a stated trial count**, with the full trial ledger in the report - a 2/50 result is reportable as 2/50, never as "reproducible."
7. **Data you will encounter.** RAG corpora, agent memory, vector stores, and inference logs can contain third-party PII, secrets, and conversation content. Capture the minimum proof (a hash, a redacted fragment, a record count), never bulk-collect, never retain, and report immediately. Discovery of real user data is a Section 6 stop condition.
8. **Model artifacts are untrusted code.** Never load, unpickle, deserialize, or execute a model artifact, adapter, notebook, or config obtained from a target. Inspect statically, offline, in an isolated environment.
9. **Agent and tool boundaries.** A test agent must hold the least-privileged tool set that can prove the point, prefer echo/no-op tools for proof, and never chain into out-of-scope systems. You are responsible for every action your agent takes, including ones an injection induced.
10. **Be identifiable.** Where the program permits it, mark traffic (identifying header or user agent) and register test accounts, so defenders do not burn incident-response cycles on you.
11. **Additional stop conditions.** Stop, preserve, and escalate on: evidence another party is exploiting the same defect; any probe that begins to affect other tenants' sessions, outputs, or costs; a training-data or memory extraction that starts returning real user content; or a finding that cannot be proven without generating genuinely harmful content.

8. Defect-class registry and AI evidence notation

8.1 Defect-class prefixes

Every bug-bounty playbook in this library numbers its defect classes with a unique prefix, so a class ID is globally unambiguous in a report, a ticket, or a triage queue. Never reuse a prefix.

Prefix	Range	Owning playbook	Domain
C	C1-C15	PB-08	Cryptographic implementation & PQ migration defects
L	L1-L14	PB-16	LLM application layer
S	S1-S10	PB-17	AI supply chain & model artifacts
G	G1-G12	PB-18	Agentic systems, tools & the MCP boundary
I	I1-I10	PB-20	Inference infrastructure & multi-tenant isolation

A finding cites exactly one primary class. Chains cite the primary class and list the others in sequence (L2 -> L5 -> L6), because the chain is what carries the impact.

Three playbooks own no prefix by design. **PB-07** and **PB-15** are methodology, not catalogs - their findings carry the class of whichever catalog the defect belongs to. **PB-19** covers model *behavior*, which routes to a program's model-safety channel rather than its security queue (Section 7.1); giving those findings a class ID would invite a triager to treat them as security defects.

The TX (Transmission & Physical Layer) collection owns no prefix either. TX-01 and TX-02 are detection and response playbooks, not bug-bounty catalogs; their intrusion classes are descriptive (*bend-tap*, *rogue-lambda*, *ROADM/monitor*, *impersonation*, *reception-anomaly*) and are cited by name. A registry prefix would invite a triager to read a physical-medium event as an application defect. Note also that C10 in PB-08 covers **computational** side channels - timing, fault, and secret residue. Electromagnetic emanation (TX-01 Section 5.7) and optical emission (TX-02 Section 6.7) are different physical phenomena and are deliberately not filed under C10.

8.2 Canary tokens

Inert markers are the sanctioned proof mechanism for AI findings (Section 7.4). Format:

```
GNBB-CANARY-<uuid4>          e.g. GNBB-CANARY-3f2a1c68-9d47-4e2b-8a10-5c7e9b04d1f6
```

Canaries are registered in the engagement's canary registry before use, are unique per probe and per tenant, and carry no semantic content. A retrieval, leakage, propagation, or tool-invocation claim is proven by the canary appearing where it should not - not by narrative description.

8.3 Trial-ledger notation for stochastic findings

Per Section 7.6, AI findings report reproducibility as a ledger, never as an adjective. The canonical short form in a report title or triage summary is:

```
successes/trials @ temperature (95% CI low-high)    e.g. 7/20 @ t=1.0 (0.18-0.57)
```

Report templates may label the interval 95% Wilson CI where the form needs to be unambiguous; the short form above stays canonical for titles and triage summaries.

The interval is a **Wilson score interval** - with the small trial counts an authorized, rate-limited engagement can afford, a normal-approximation interval is wrong at the tails and a bare percentage is meaningless. 2/50 is reported as 2/50, and is still a real finding when the consequence is real and the attacker's retry cost is low; severity comes from consequence and retry economics, not from the rate alone.

9. Versioned reference baseline

These sources are the audit baseline for the collection. Record the retrieval date in any compliance evidence package and re-check status before deployment:

- NIST Post-Quantum Cryptography project - authoritative status for FIPS 203/204/205, FIPS 206 development, HQC selection, and future PQ standards.
- NIST SP 800-227 - KEM construction and implementation guidance.
- NIST CSWP 39-upd1 - final June 2026 crypto-agility guidance.
- IETF ECDHE-MLKEM TLS draft and the IANA TLS Supported Groups registry - current protocol status and code points; an Internet-Draft is not an RFC.

- NIST AI RMF and NIST AI 600-1 GenAI Profile - enterprise AI governance, mapping, measurement, and management baseline.
 - NIST CSF 2.0 - Govern, Identify, Protect, Detect, Respond, and Recover outcomes.
 - CISA JCDC AI Cybersecurity Collaboration Playbook - AI incident coordination and information-sharing baseline.
 - OWASP Top 10 for LLM Applications 2025 and OWASP Top 10 for Agentic Applications 2026 - application and agentic risk cross-checks.
 - Executive Order 14412 fact sheet and OMB M-23-02 - federal PQ migration direction; determine applicability before treating either as binding.
 - PCI SSC FAQ 1491 - PQ TLS is described as best practice; PCI DSS does not currently impose a general PQ migration mandate.
-

GreyNOC - detection-engineering-first. Reproducible or it didn't happen.